

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN**



BẢO MẬT TRONG IOT

CHỐNG REPLAY ATTACK TRONG GIAO TIẾP IOT

GIẢNG VIÊN GIẢNG DẠY: Hồ Nhật Minh

HỌ VÀ TÊN HỌC VIÊN: Phạm Ngọc Anh

LỚP HỌC PHẦN: 253INT441001

MSSV: 231A010382

MÃ ĐỀ TÀI: 24

TP. HỒ CHÍ MINH - 2026

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN**



BẢO MẬT TRONG IOT

CHỐNG REPLAY ATTACK TRONG GIAO TIẾP IOT

TP. HCM, NĂM 2026

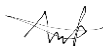
THÔNG TIN VÀ CAM KẾT NỘP BÀI

Mã đề tài	24
Hướng đề tài	Chống replay attack trong giao tiếp IoT (hướng D)
Sinh viên	Phạm Ngọc Anh
Mã số sinh viên	231A010382
Lớp học phần	253INT441001
Giảng viên	Hồ Nhựt Minh
Link repo GitHub	https://github.com/NgAnh205/NgAnh-Chong-Replay-Attack-IoT
Ngày nộp	31/07/2026

Cam kết an toàn và học thuật

Tôi cam kết toàn bộ thực nghiệm trong đồ án được thực hiện trong môi trường mô phỏng cục bộ và trên các thiết bị thuộc quyền sở hữu cá nhân; tuyệt đối không quét, khai thác hay thu thập dữ liệu trái phép từ bất kỳ hệ thống thực tế nào. Báo cáo, mã nguồn và các minh chứng đi kèm là kết quả làm việc độc lập của cá nhân; mọi nội dung kế thừa hoặc tham khảo đều được trích dẫn nguồn gốc rõ ràng. Kho lưu trữ mã nguồn (Repository) phục vụ đồ án hoàn toàn không chứa secret key thực tế, token, mật khẩu hay bất kỳ dữ liệu cá nhân nào.

Về việc sử dụng Trí tuệ nhân tạo (AI) trong quá trình nghiên cứu: Tôi xin minh bạch tuyên bố rằng đồ án này có sử dụng công cụ AI (Google Gemini, Claude AI) để hỗ trợ các công việc bao gồm: kiểm tra ngôn ngữ, hiệu đính văn phong báo cáo, và hỗ trợ hoàn thiện các cấu trúc mã lệnh cơ bản phục vụ kịch bản kiểm thử. Công cụ này chỉ đóng vai trò hỗ trợ phụ trợ; toàn bộ ý tưởng thiết kế cốt lõi, kiến trúc phòng thủ, quá trình phân tích số liệu thực nghiệm và kết luận của công trình đều do tôi tự thực hiện. Tôi xin chịu trách nhiệm hoàn toàn về tính nguyên bản, tính chính xác học thuật cũng như toàn bộ nội dung và kết quả được trình bày trong báo cáo này.

- Họ tên người cam kết: Phạm Ngọc Anh
- Ngày cam kết: 31/07/2026
- Chữ ký: 

TP. HỒ CHÍ MINH, 2026

CHECKLIST TIẾN ĐỘ THỰC HIỆN ĐỀ TÀI

Tuần / Giai đoạn	Nội dung công việc thực hiện	Trạng thái	Minh chứng (Số trang / Commit)
Tuần 01	Hoàn thiện đề cương, xác định tên đề tài (Mã đề tài 24 - Hướng D), mục tiêu, phạm vi và dàn ý báo cáo ban đầu.	☒ Đạt ☐ Bổ sung	Trang 4–5 (commit Tuan01)
Tuần 02	Hoàn thành Chương 1 (Tổng quan đề tài), viết bản nháp 50-70% Chương 2 (Cơ sở lý thuyết) và lập danh mục tài liệu.	☒ Đạt ☐ Bổ sung	Trang 5–8 (commit Tuan02)
Tuần 03	Hoàn thành Chương 2 và viết Chương 3 (Phương pháp, thiết kế mô hình hệ thống chống replay, lập quy trình đánh giá).	☒ Đạt ☐ Bổ sung	Trang 9–11 (commit Tuan03)
Tuần 04	Viết Chương 4 (Triển khai môi trường Wokwi, Mosquitto Broker, viết kịch bản Python và thu log kết quả chạy kiểm thử).	☒ Đạt ☐ Bổ sung	Trang 12–18 (commit Tuan04)
Tuần 05	Viết Chương 5 (Đánh giá bảo mật: tài sản, STRIDE, ma trận rủi ro R1–R6, biện pháp giảm thiểu) và Chương 6 (Kết luận, hạn chế, hướng phát triển).	☒ Đạt ☐ Bổ sung	Trang 26–35 (commit Tuan05)
Repo	Cập nhật README, đồng bộ toàn bộ mã nguồn, file cấu hình và tài liệu báo cáo lên kho lưu trữ GitHub.	☒ Đạt ☐ Bổ sung	GitHub Repo

MỤC LỤC

THÔNG TIN VÀ CAM KẾT NỘP BÀI	3
CHECKLIST TIẾN ĐỘ THỰC HIỆN ĐỀ TÀI	4
DANH MỤC TỪ VIẾT TẮT	7
DANH MỤC HÌNH ẢNH	8
DANH MỤC BẢNG	9
CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI	10
1.1. Bối cảnh và lý do chọn đề tài.....	10
1.2. Phát biểu vấn đề bảo mật	10
1.3. Mục tiêu của đề tài	11
1.4. Đối tượng, phạm vi và giới hạn an toàn	11
1.5. Sản phẩm và kết quả dự kiến.....	11
1.6. Cấu trúc báo cáo.....	12
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN	12
2.1. Kiến trúc hoặc bối cảnh kỹ thuật của hệ thống.....	12
2.2. Khái niệm bảo mật trực tiếp liên quan	13
2.3. Nội dung cần nhấn mạnh theo nhóm đề tài	13
2.4. Chuẩn, công cụ và nguồn GitHub chính	15
2.5. Công trình hoặc giải pháp liên quan	16
2.6. Tiểu kết Chương 2	17
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ.....	17
3.1. Phương pháp thực hiện.....	17
3.2. Mô hình/kiến trúc đề xuất	17
3.3. Môi trường, công cụ và dữ liệu	18
3.4. Quy trình triển khai/đánh giá	19
3.5. Tiêu chí đánh giá	20
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ.....	20
4.1. Chuẩn bị môi trường.....	20
4.2. Thành phần sản phẩm	22
4.3. Kịch bản thử nghiệm/áp dụng.....	23

4.4. Kết quả	24
4.4.1. Kịch bản 1 (KB-01): Thực nghiệm giao tiếp hợp lệ (Normal Operation/Happy Path)	24
4.4.2. Kịch bản 2 (KB-02): Thực nghiệm tấn công phát lại (Replay Attack)	26
4.4.3. Kịch bản 3 (KB-03): Thực nghiệm tấn công phát lại tức thì (Immediate Replay Attack).	28
4.4.4. Kịch bản 4 (KB-04): Tấn công giả mạo dữ liệu (Command Tampering)	29
4.5. Script sinh báo cáo	31
4.6. Thảo luận và hạn chế	32
CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT	33
5.1. Tài sản và dữ liệu.....	33
5.2. Mối đe dọa và lỗ hổng	34
5.3. Ma trận rủi ro	35
5.4. Biện pháp giảm thiểu	36
5.5. Rủi ro còn lại.....	37
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN.....	37
6.1. Kết luận	37
6.2. Hạn chế.....	38
6.3. Hướng phát triển	38
DANH MỤC NGUỒN TÀI LIỆU THAM KHẢO	39

DANH MỤC TỪ VIẾT TẮT

STT	Từ viết tắt	Giải thích
1	AI	Artificial Intelligence – Trí tuệ nhân tạo
2	C/I/A	Confidentiality / Integrity / Availability – Bí mật / Toàn vẹn / Sẵn sàng
3	CoAP	Constrained Application Protocol – Giao thức ứng dụng cho thiết bị hạn chế tài nguyên
4	DDoS	Distributed Denial of Service – Tấn công từ chối dịch vụ phân tán
5	ESP32	Vi điều khiển họ Espressif 32-bit (dùng mô phỏng thiết bị IoT trong đề tài)
6	HMAC	Hash-based Message Authentication Code – Mã xác thực bản tin dựa trên hàm băm
7	HSM	Hardware Security Module – Mô-đun bảo mật phần cứng
8	IoT	Internet of Things – Vạn vật kết nối Internet
9	JSON	JavaScript Object Notation – Định dạng dữ liệu dùng cho payload bản tin
10	Kdev	Khóa bí mật chia sẻ giữa thiết bị (Device) và Gateway, dùng để tính HMAC
11	MQTT	Message Queuing Telemetry Transport – Giao thức truyền tin nhẹ dùng trong IoT
12	NIST	National Institute of Standards and Technology – Viện Tiêu chuẩn và Công nghệ Hoa Kỳ
13	NTP	Network Time Protocol – Giao thức đồng bộ thời gian mạng
14	OSCORE	Object Security for Constrained RESTful Environments
15	OWASP	Open Worldwide Application Security Project
16	PKI	Public Key Infrastructure – Hạ tầng khóa công khai
17	RFC	Request for Comments – Tài liệu đặc tả tiêu chuẩn Internet (IETF)

DANH MỤC HÌNH ẢNH

<i>Hình 2. 1 - Sơ đồ kiến trúc và ranh giới tin cậy của hệ thống khóa cửa IoT</i>	<i>12</i>
<i>Hình 2. 2- Attack tree: Replay attack trong hệ thống khóa cửa IoT</i>	<i>14</i>
<i>Hình 3. 1 - Mô hình đề xuất: chống replay bằng Timestamp + Sequence Number + Nonce + HMAC.....</i>	<i>18</i>
<i>Hình 4. 1 - Cấu hình MQTT Broker và khởi chạy Gateway xử lý chống Replay Attack trên Ubuntu.....</i>	<i>21</i>
<i>Hình 4. 2 - Khởi chạy kịch bản Attacker mô phỏng hành vi xâm nhập MQTT Broker trên Ubuntu.....</i>	<i>22</i>
<i>Hình 4. 3 - Thiết bị IoT phát lệnh</i>	<i>25</i>
<i>Hình 4. 4 - Gateway xác thực thành công và chấp nhận bản tin hợp lệ từ thiết bị IoT</i>	<i>26</i>
<i>Hình 4. 5 - Kết quả thực nghiệm hệ thống Gateway từ chối gói tin lặp lại (Replay Attack).</i>	<i>27</i>
<i>Hình 4. 6 - Kết quả thực nghiệm hệ thống Gateway từ chối gói tin lặp lại (Replay Attack).</i>	<i>29</i>
<i>Hình 4. 7 - Kết quả thực nghiệm hệ thống Gateway từ chối gói tin bị can thiệp nội dung.</i>	<i>30</i>

DANH MỤC BẢNG

<i>Bảng 1. 1 – Sản phẩm và kết quả dự kiến theo mục tiêu</i>	<i>11</i>
<i>Bảng 2. 1 - Ánh xạ STRIDE cho hệ thống khóa cửa IoT, tập trung vào nguy cơ replay attack.</i>	<i>15</i>
<i>Bảng 3. 1 – Môi trường, công cụ và dữ liệu sử dụng trong thực nghiệm.</i>	<i>19</i>
<i>Bảng 3. 2 – Quy trình triển khai và đánh giá</i>	<i>19</i>
<i>Bảng 4. 1 – Kịch bản thử nghiệm cơ chế chống replay.....</i>	<i>23</i>
<i>Bảng 4. 2 - Kết quả thực nghiệm tổng hợp theo từng kịch bản, đối chiếu tiêu chí đánh giá.</i>	<i>31</i>
<i>Bảng 5. 1 - Danh mục tài sản cần bảo vệ trong hệ thống khóa cửa IoT.....</i>	<i>34</i>
<i>Bảng 5. 2 - Ánh xạ STRIDE vào hệ thống khóa cửa IoT, đối chiếu với kết quả thực nghiệm Chương 4.</i>	<i>34</i>
<i>Bảng 5. 3 - Ma trận rủi ro trước và sau khi áp dụng cơ chế chống replay.</i>	<i>35</i>
<i>Bảng 5. 4 - Bảng ưu tiên xử lý rủi ro còn tồn tại.....</i>	<i>35</i>
<i>Bảng 5. 5 - Biện pháp giảm thiểu theo từng rủi ro, phân biệt bảo vệ kênh và bảo vệ đầu-cuối.</i>	<i>36</i>
<i>Bảng 6. 1 - Đối chiếu mục tiêu đề tài với kết quả đạt được.</i>	<i>37</i>

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

Mức hoàn thành yêu cầu: Chương 1 phải hoàn thành 100% trong Tuần 02, dài khoảng 2-3 trang. Viết theo đúng đề tài được giao, không mở đầu bằng phần định nghĩa IoT chung kéo dài.

1.1. Bối cảnh và lý do chọn đề tài

Các thiết bị Internet of Things (IoT) như khóa cửa thông minh, camera an ninh, cảm biến báo động đang được lắp đặt phổ biến tại nhà dân và văn phòng nhỏ nhờ chi phí thấp và khả năng điều khiển từ xa qua ứng dụng di động. Tuy nhiên, phần lớn thiết bị dân dụng ưu tiên tính tiện dụng và giá thành hơn là bảo mật: giao thức truyền thông (thường là MQTT hoặc HTTP) đôi khi không bật mã hóa TLS, và cơ chế xác thực bản tin chỉ dựa vào nội dung cố định (mã lệnh, mật khẩu tĩnh) mà không có yếu tố chống lặp lại. Đây là điều kiện thuận lợi cho một dạng tấn công đơn giản nhưng nguy hiểm: replay attack (tấn công phát lại) - kẻ tấn công không cần biết khóa bí mật, chỉ cần nghe trộm và gửi lại đúng bản tin hợp lệ đã từng được truyền đi để khiến hệ thống thực thi lại hành động đó (ví dụ mở khóa cửa). Nhóm nghiên cứu chọn đề tài này vì replay attack là một trong những lỗ hổng thường bị đánh giá thấp trong thiết kế IoT dân dụng, dễ tái hiện trong môi trường mô phỏng/lab (không cần khai thác phần cứng phức tạp), nhưng lại minh họa rất rõ các khái niệm cốt lõi của bảo mật giao tiếp: toàn vẹn (Integrity), xác thực (Authentication) và tính tươi mới của dữ liệu (Freshness). Việc phân tích, mô hình hóa và đề xuất giải pháp phòng chống cho lớp tấn công này giúp sinh viên vận dụng đồng thời kiến thức về mật mã đối xứng (HMAC), quản lý trạng thái (sequence number, cửa sổ thời gian) và tư duy mô hình hóa mối đe dọa (STRIDE, attack tree).

1.2. Phát biểu vấn đề bảo mật

Kịch bản tấn công cụ thể được khảo sát trong đề tài: một hệ thống khóa cửa IoT gồm thiết bị khóa (gắn vi điều khiển, kết nối Wi-Fi) gửi các bản tin điều khiển (UNLOCK/LOCK) tới một gateway nội bộ qua giao thức MQTT. Kẻ tấn công M có khả năng nghe trộm lưu lượng trên cùng phân đoạn mạng Wi-Fi (ví dụ khi mạng dùng WPA2-Personal với khóa yếu, hoặc khi kênh MQTT chưa bật TLS/mTLS). M ghi lại (capture) một bản tin UNLOCK hợp lệ đã được gửi trước đó bởi chủ nhà, sau đó tại một thời điểm bất kỳ sau này, M phát lại (replay) chính xác bản tin đó tới gateway. Nếu gateway không có cơ chế phân biệt bản tin "mới" và bản tin "cũ đã dùng", nó sẽ chấp nhận bản tin phát lại như một lệnh hợp lệ và mở khóa cửa - dẫn đến truy cập vật lý trái phép mà không cần bẻ khóa mật mã hay biết khóa bí mật của hệ thống. Vấn đề bảo mật cốt lõi cần giải quyết là: làm thế nào để bên nhận (gateway) phân biệt được một bản tin hợp lệ mới với một bản tin hợp lệ cũ bị phát lại, trong điều kiện thiết bị IoT có tài nguyên tính toán và năng lượng hạn chế, mà không làm tăng đáng kể độ trễ hoặc độ phức tạp triển khai.

1.3. Mục tiêu của đề tài

1. Phân tích và mô hình hóa nguy cơ replay attack trong hệ thống khóa cửa IoT bằng attack tree và bảng STRIDE. Sản phẩm đầu ra: Hình 2.2 (attack tree) và Bảng 2.1 (STRIDE) ở Chương 2.
2. Thiết kế cơ chế chống replay dựa trên kết hợp Timestamp + Sequence Number + Nonce + HMAC cho luồng giao tiếp thiết bị - gateway. Sản phẩm đầu ra: Hình 3.1 (mô hình đề xuất) và đặc tả giao thức ở Chương 3.
3. Triển khai mô phỏng cơ chế trên môi trường Wokwi (ESP32) + MQTT Broker Mosquitto, thu thập log/ảnh minh chứng cho các kịch bản ACCEPT/REJECT. Sản phẩm đầu ra: mã nguồn, cấu hình, log tại Chương 4.
4. Đánh giá hiệu quả cơ chế qua tỉ lệ phát hiện/chặn replay đúng, độ trễ xử lý bổ sung, và đối chiếu với ma trận rủi ro. Sản phẩm đầu ra: bảng số liệu và ma trận rủi ro ở Chương 4 - 5.

1.4. Đối tượng, phạm vi và giới hạn an toàn

Đối tượng nghiên cứu là luồng giao tiếp giữa thiết bị khóa cửa IoT và gateway nội bộ trong mạng gia đình, cụ thể là bản tin điều khiển truyền qua giao thức MQTT. Phạm vi đề tài giới hạn ở lớp giao tiếp thiết bị - gateway (không mở rộng sang phân tích firmware, phần cứng, hay kênh gateway - cloud). Toàn bộ thực nghiệm được thực hiện trong môi trường mô phỏng/lab tự dựng (Wokwi giả lập ESP32, Mosquitto broker chạy local hoặc Docker); nhóm không thực hiện tấn công lên bất kỳ hệ thống thật, thiết bị của bên thứ ba, hoặc hạ tầng mạng không thuộc quyền sở hữu/quản lý của nhóm, tuân thủ nguyên tắc đạo đức nghiên cứu an toàn thông tin.

1.5. Sản phẩm và kết quả dự kiến

Mục tiêu	Sản phẩm đầu ra	Cách kiểm chứng	Trình bày ở chương
MT-01	Attack tree + bảng STRIDE	Đối chiếu kịch bản tấn công với sơ đồ, phản biện logic AND/OR	Chương 2
MT-02	Mô hình/đặc tả giao thức chống replay	So khớp đặc tả với sơ đồ tuần tự Hình 3.1	Chương 3
MT-03	Code, config, log mô phỏng	Log thực tế từ repo GitHub, ảnh chụp môi trường chạy	Chương 4
MT-04	Bảng số liệu đánh giá, ma trận rủi ro	Số liệu đối chiếu tiêu chí 3.5 (đạt/chưa đạt)	Chương 4-5

Bảng 1. 1 – Sản phẩm và kết quả dự kiến theo mục tiêu

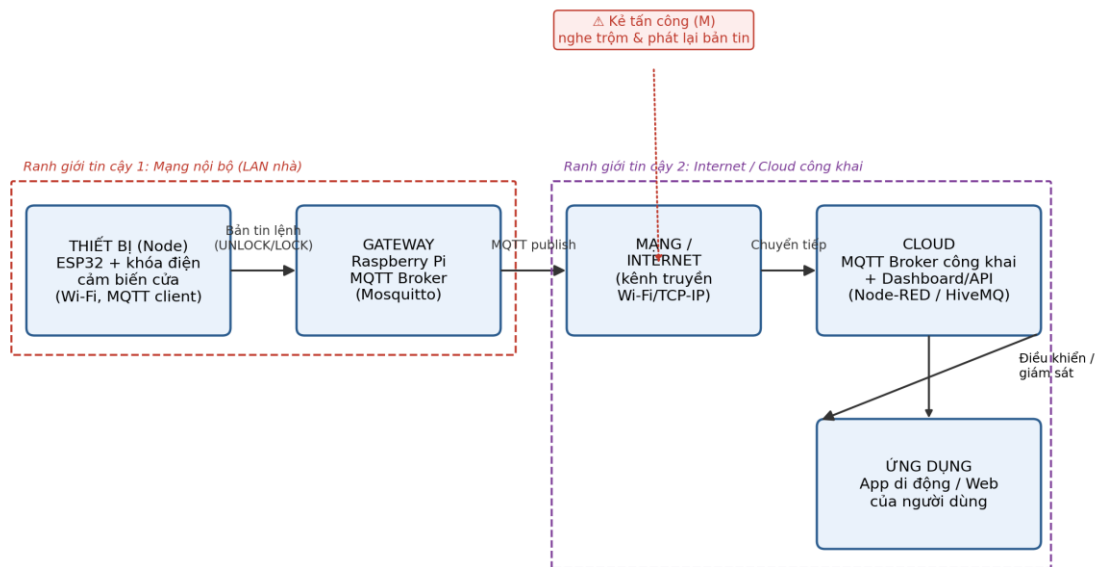
1.6. Cấu trúc báo cáo

Báo cáo được tổ chức thành 6 chương. Chương 1 giới thiệu bối cảnh, vấn đề và mục tiêu. Chương 2 trình bày cơ sở lý thuyết và các khái niệm bảo mật liên quan đến replay attack. Chương 3 mô tả phương pháp thực hiện và thiết kế cơ chế phòng chống đề xuất. Chương 4 trình bày quá trình triển khai mô phỏng và kết quả thử nghiệm. Chương 5 đánh giá bảo mật tổng thể của hệ thống sau khi áp dụng biện pháp. Chương 6 tổng kết, đối chiếu mục tiêu và đề xuất hướng phát triển.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc hoặc bối cảnh kỹ thuật của hệ thống

Hệ thống khóa cửa IoT được khảo sát gồm 5 thành phần chính: (1) Thiết bị (khóa điện + vi điều khiển ESP32, đóng vai trò MQTT client, publish trạng thái và nhận lệnh điều khiển); (2) Gateway đặt trong mạng nhà, chạy MQTT Broker (Mosquitto) và logic kiểm tra bảo mật; (3) Mạng/Internet là kênh truyền giữa gateway và cloud; (4) Cloud gồm broker công khai hoặc dịch vụ trung gian (ví dụ HiveMQ, Node-RED) cùng dashboard giám sát; (5) Ứng dụng di động/web của người dùng dùng để gửi lệnh và xem trạng thái. Hình 2.1 minh họa kiến trúc tổng thể cùng hai ranh giới tin cậy: ranh giới mạng nội bộ (giữa thiết bị và gateway) và ranh giới Internet/Cloud công khai (giữa gateway và ứng dụng người dùng thông qua cloud).



Hình 2. 1 - Sơ đồ kiến trúc và ranh giới tin cậy của hệ thống khóa cửa IoT

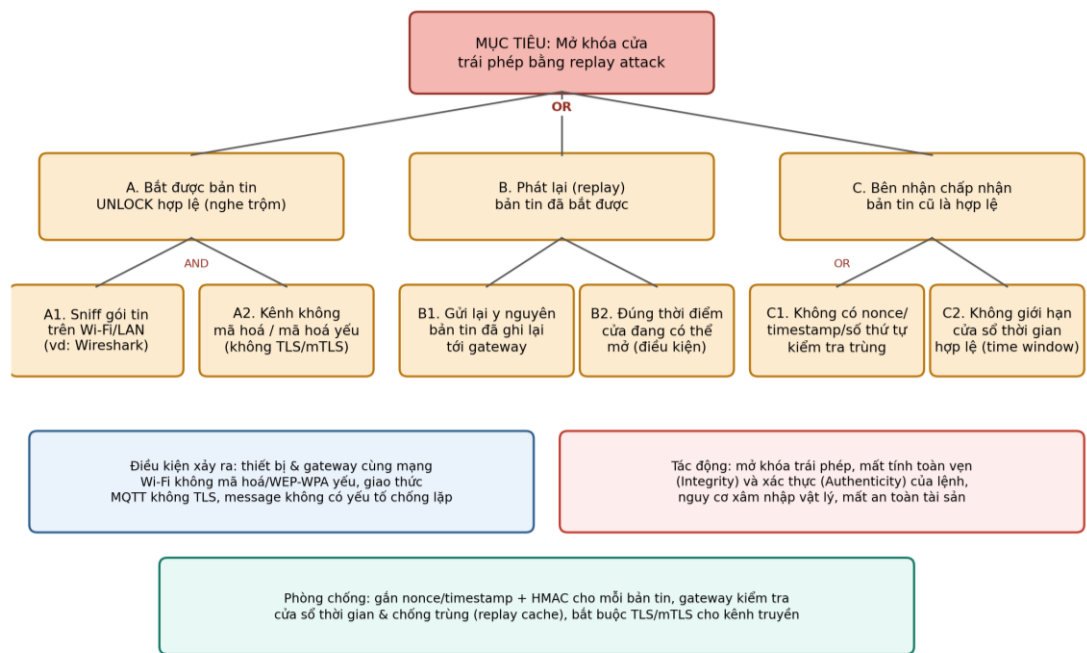
Ranh giới tin cậy thứ nhất là nơi rủi ro replay attack tập trung nhất trong phạm vi đề tài, vì đây là đoạn mạng mà kẻ tấn công dễ tiếp cận vật lý (đứng trong vùng phủ Wi-Fi) để nghe trộm và phát lại bản tin, trong khi đoạn gateway–cloud thường đã được bảo vệ tốt hơn bằng TLS mặc định của các nền tảng cloud phổ biến.

2.2. Khái niệm bảo mật trực tiếp liên quan

Khái niệm	Giải thích + ví dụ trong đề tài
Tài sản (Asset)	Đối tượng cần bảo vệ. Ví dụ trong đề tài: bản tin lệnh UNLOCK/LOCK và trạng thái khóa cửa.
Mối đe dọa (Threat)	Khả năng gây hại cho tài sản. Ví dụ: kẻ tấn công phát lại bản tin để mở khóa trái phép.
Lỗ hổng (Vulnerability)	Điểm yếu bị khai thác. Ví dụ: bản tin MQTT không có nonce/timestamp, kênh không TLS.
Rủi ro (Risk)	Xác suất mối đe dọa khai thác lỗ hổng nhân với mức thiệt hại. Ví dụ: rủi ro mở khóa trái phép khi mạng Wi-Fi công khai.
Tính toàn vẹn (Integrity)	Bảo đảm bản tin không bị sửa đổi/giả mạo trên đường truyền. HMAC giúp phát hiện sửa đổi.
Xác thực (Authentication)	Bảo đảm bản tin thực sự đến từ thiết bị hợp lệ. Khóa chia sẻ Kdev dùng để tính HMAC đóng vai trò xác thực nguồn gốc, theo đặc tả HMAC ở RFC 2104 [3].
Tính tươi (Freshness)	Bảo đảm bản tin là mới, chưa từng được xử lý trước đó - chống lại đúng replay attack. Đạt được bằng timestamp/sequence/nonce, khái niệm được tham chiếu từ NIST SP 800-63B [2].
STRIDE	Mô hình phân loại 6 nhóm mối đe dọa (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege), dùng để rà soát hệ thống một cách hệ thống, tham chiếu danh mục lỗ hổng IoT của OWASP [1].

2.3. Nội dung cần nhấn mạnh theo nhóm đề tài

Theo hướng D, đề tài tập trung phân tích mô hình tấn công replay theo 3 giai đoạn: (1) Thu thập - kẻ tấn công nghe trộm và ghi lại một bản tin lệnh hợp lệ; (2) Phát lại - kẻ tấn công gửi lại chính xác bản tin đó tại một thời điểm khác; (3) Chấp nhận sai - bên nhận không có cơ chế phân biệt bản tin cũ/mới nên thực thi lại hành động. Hình 2.2 trình bày attack tree mô tả các nhánh điều kiện (AND/OR) cần thỏa mãn để cuộc tấn công thành công.



Hình 2. 2- Attack tree: Replay attack trong hệ thống khóa cửa IoT

Điều kiện xảy ra: cuộc tấn công chỉ thành công khi đồng thời (a) kênh truyền thiết bị - gateway không mã hóa hoặc mã hóa yếu để kẻ tấn công có thể sniff được bản tin gốc, và (b) gateway không kiểm tra tính mới của bản tin (không có nonce/timestamp/sequence number, hoặc không giới hạn cửa sổ thời gian hợp lệ). Nếu chỉ một trong hai điều kiện được khắc phục, đường tấn công bị chặn.

Tác động: nếu thành công, kẻ tấn công có thể mở khóa cửa trái phép mà không cần biết mật khẩu hay khóa bí mật của hệ thống, vi phạm trực tiếp tính toàn vẹn và xác thực của lệnh điều khiển, dẫn đến nguy cơ xâm nhập vật lý và mất an toàn tài sản của người dùng - mức độ ảnh hưởng cao dù độ phức tạp kỹ thuật của tấn công thấp.

Phòng chống: gắn thêm yếu tố chống lặp lại (timestamp, sequence number, nonce) và mã xác thực bản tin (HMAC) vào mỗi lệnh; phía gateway kiểm tra cửa sổ thời gian hợp lệ và duy trì bộ nhớ đệm (replay-cache) các nonce/sequence đã dùng; đồng thời bắt buộc bật TLS/mTLS cho kênh MQTT để giảm khả năng bị nghe trộm ngay từ đầu. Bảng 2.1 dưới đây tổng hợp các mối đe dọa theo mô hình STRIDE, có tham chiếu đến danh mục lỗ hổng phổ biến của OWASP IoT [1], trong đó replay attack chủ yếu rơi vào nhóm Spoofing và Tampering.

Nhóm STRIDE	Mối đe dọa trong hệ thống	Mức rủi ro (Thấp/TB/Cao)	Biện pháp giảm thiểu tương ứng
Spoofing	Giả danh thiết bị hợp lệ bằng cách phát lại bản tin đã ghi được	Cao	HMAC với khóa chia sẻ Kdev, xác thực nguồn gốc bản tin

Nhóm STRIDE	Mối đe dọa trong hệ thống	Mức rủi ro (Thấp/TB/Cao)	Biện pháp giảm thiểu tương ứng
Tampering	Sửa đổi bản tin trên đường truyền trước khi chuyển tiếp	Trung bình	HMAC phát hiện thay đổi payload; TLS/mTLS bảo vệ kênh
Repudiation	Không thể xác minh ai thực sự gửi lệnh UNLOCK khi có tranh chấp	Trung bình	Ghi log kèm device_id, seq, timestamp cho mọi bản tin ACCEPT/REJECT
Information Disclosure	Kẻ tấn công đọc được nội dung bản tin khi sniff mạng	Cao	Mã hóa kênh truyền (TLS/mTLS), không gửi payload dạng plaintext
Denial of Service	Gửi ồ ạt bản tin phát lại/sai để làm quá tải replay-cache của gateway	Thấp	Giới hạn tốc độ (rate-limit) theo device_id, giới hạn kích thước cache
Elevation of Privilege	Lợi dụng lệnh UNLOCK phát lại để có quyền truy cập vật lý ngoài ý muốn chủ nhà	Cao	Kết hợp kiểm tra cửa sổ thời gian + sequence number trước khi thực thi lệnh

Bảng 2. 1 - Ảnh xạ STRIDE cho hệ thống khóa cửa IoT, tập trung vào nguy cơ replay attack.

2.4. Chuẩn, công cụ và nguồn GitHub chính

ST T	Nguồn/repo	URL/piên bản	Phần đã sử dụng	Truy cập
1	OWASP IoT Top 10	https://owasp.org/www-project-internet-of-things/	Đối chiếu mối đe dọa ở mục 2.3, 5.2	06/07/2026
2	NIST SP 800-63B (Digital Identity - Authentication)	https://pages.nist.gov/800-63-3/sp800-63b.html	Khái niệm xác thực, freshness ở mục 2.2	06/07/2026
3	RFC 2104 - HMAC	https://www.rfc-editor.org/rfc/rfc2104	Thiết kế cơ chế MAC ở Chương 3	15/07/2026
4	Mosquitto MQTT Broker (docs) [4]	https://mosquitto.org/documentation/	Cấu hình gateway ở Chương 3 - 4	25/07/2026

ST T	Nguồn/repo	URL/phiên bản	Phần đã sử dụng	Truy cập
5	Wokwi ESP32 Simulator [5]	https://docs.wokwi.com/	Mô phỏng thiết bị ở Chương 4	30/07/2026
6	NgAnh205/NgAnh-Chong-Replay-Attack-IoT	https://github.com/NgAnh205/NgAnh-Chong-Replay-Attack-IoT	Lưu code, config, log toàn bộ đề tài	31/07/2026

2.5. Công trình hoặc giải pháp liên quan

Nguồn/giải pháp	Mục tiêu	Cách làm	Ưu điểm	Nhược điểm / phần đề tài kế thừa
OWASP IoT Top 10 (I3: Insecure network services / thiếu cơ chế chống replay)	Liệt kê các lỗ hổng phổ biến ở thiết bị IoT, trong đó có thiếu bảo vệ chống replay	Khảo sát, phân loại lỗ hổng thực tế theo cộng đồng	Được cộng đồng an toàn thông tin công nhận rộng rãi, dễ đối chiếu	Chỉ liệt kê lỗ hổng ở mức tổng quát, không đưa ra thiết kế cụ thể - đề tài kế thừa danh mục này để định hướng STRIDE ở mục 2.3
Giao thức xác thực dùng Nonce + HMAC trong các chuẩn IoT nhẹ (ví dụ CoAP với OSCORE)	Bảo vệ tính toàn vẹn và chống replay cho thiết bị tài nguyên hạn chế	Gắn nonce/sequence vào mỗi bản tin, xác thực bằng khóa đối xứng	Nhẹ, phù hợp vì điều khiển, không cần hạ tầng PKI phức tạp	Đề tài áp dụng đúng nguyên lý này nhưng đơn giản hóa cho ngữ cảnh MQTT/lab, không dùng OSCORE đầy đủ
Giải pháp TLS/mTLS mặc định của các nền tảng MQTT cloud (HiveMQ, AWS IoT Core)	Bảo vệ kênh truyền khỏi nghe trộm và giả mạo ở tầng vận chuyển	Thiết lập chứng thực số cho thiết bị và broker	Chống nghe trộm hiệu quả ở tầng mạng, được hỗ trợ sẵn bởi nhiều nền tảng	Không tự chống được replay ở tầng ứng dụng nếu kẻ tấn công có trong mạng hợp lệ - đề tài bổ sung lớp chống replay ở tầng

Nguồn/giải pháp	Mục tiêu	Cách làm	Ưu điểm	Nhược điểm / phần đề tài kế thừa
				ứng dụng bên cạnh TLS

2.6. Tiểu kết Chương 2

Chương 2 đã trình bày kiến trúc tổng thể của hệ thống khóa cửa IoT cùng các khái niệm bảo mật nền tảng, đồng thời phân tích chi tiết mô hình tấn công replay theo hướng D bằng attack tree và bảng STRIDE, làm rõ điều kiện xảy ra, tác động và hướng phòng chống. Trên cơ sở đó, Chương 3 sẽ trình bày phương pháp thực hiện cụ thể và thiết kế cơ chế chống replay đề xuất, làm nền tảng để triển khai và đánh giá ở các chương sau.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

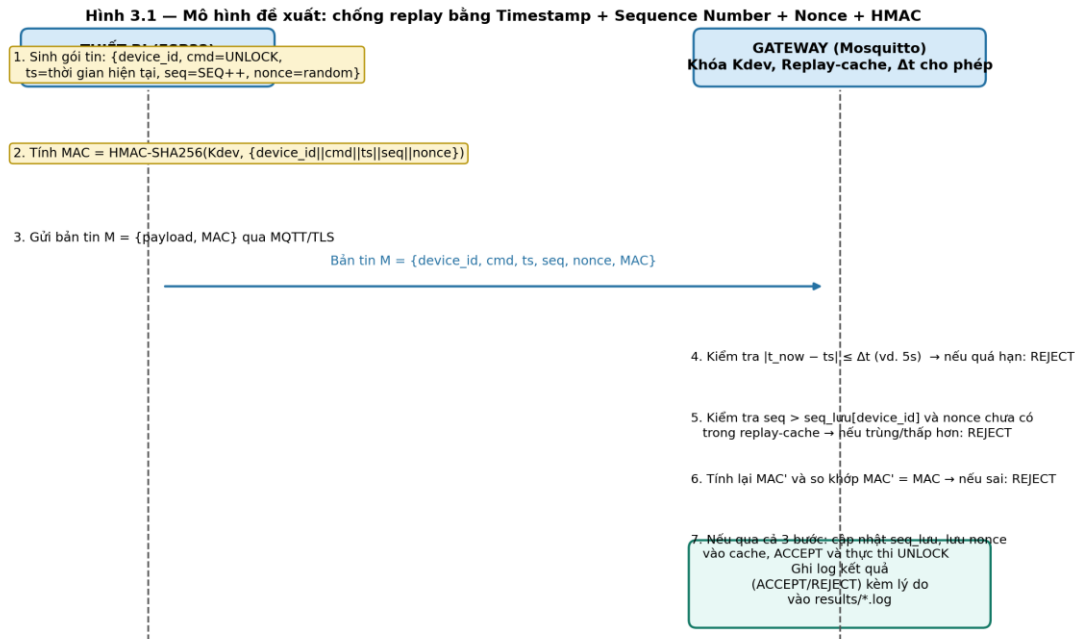
3.1. Phương pháp thực hiện

- Bước 1. Khảo sát: tìm hiểu kiến trúc IoT phổ biến cho khóa cửa thông minh và các lỗ hổng đã được ghi nhận (OWASP, tài liệu Mosquitto/MQTT); công cụ: tra cứu tài liệu, đọc RFC/OWASP. Sản phẩm: nội dung Chương 1 - 2.
- Bước 2. Thiết kế: xây dựng attack tree, bảng STRIDE và đặc tả giao thức chống replay (Timestamp + Sequence + Nonce + HMAC); công cụ: sơ đồ hóa bằng Python/matplotlib, đặc tả bằng văn bản. Sản phẩm: Hình 2.2, Bảng 2.1, Hình 3.1.
- Bước 3. Dựng lab/mô phỏng: cấu hình MQTT Broker Mosquitto (local/Docker) làm gateway, mô phỏng thiết bị ESP32 trên Wokwi chạy firmware gửi bản tin theo đặc tả; công cụ: Docker, Wokwi, VS Code/PlatformIO. Sản phẩm: mã nguồn, file cấu hình trong repo.
- Bước 4. Thử nghiệm: viết script Python đóng vai kẻ tấn công để bắt và phát lại bản tin hợp lệ, đối chiếu với các kịch bản tấn công đã thiết kế; công cụ: Python + thư viện paho-mqtt. Sản phẩm: log ACCEPT/REJECT, ảnh chụp minh chứng.
- Bước 5. Đánh giá: đối chiếu kết quả thử nghiệm với tiêu chí ở mục 3.5 (tỉ lệ chặn đúng, độ trễ), cập nhật ma trận rủi ro ở Chương 5; công cụ: Python (pandas) tính toán số liệu. Sản phẩm: bảng số liệu, ma trận rủi ro.

3.2. Mô hình/kiến trúc đề xuất

Cơ chế chống replay được đề xuất kết hợp bốn yếu tố: (1) Timestamp - mỗi bản tin mang thời điểm phát sinh, gateway chỉ chấp nhận bản tin trong cửa sổ thời gian cho phép (Δt , ví dụ 5 giây) để giới hạn thời gian sống của một bản tin bị bắt được; (2) Sequence Number -

bộ đếm tăng dần riêng cho từng thiết bị, gateway lưu số thứ tự gần nhất đã chấp nhận và từ chối các bản tin có số thứ tự nhỏ hơn hoặc bằng; (3) Nonce - giá trị ngẫu nhiên dùng một lần, được gateway lưu trong một replay-cache có thời gian sống bằng cửa sổ Δt để phát hiện các bản tin trùng lặp gửi lại gần như ngay lập tức; (4) HMAC - mã xác thực bản tin tính từ khóa chia sẻ Kdev giữa thiết bị và gateway, bảo đảm cả timestamp, sequence và nonce không thể bị kẻ tấn công tùy ý sửa đổi mà không bị phát hiện, triển khai theo đúng cấu trúc HMAC được đặc tả trong RFC 2104 [3]. Hình 3.1 minh họa luồng xử lý tuần tự của cơ chế này giữa thiết bị và gateway.



Hình 3. 1 - Mô hình đề xuất: chống replay bằng Timestamp + Sequence Number + Nonce + HMAC

Lựa chọn thiết kế: nhóm chọn kết hợp cả timestamp và sequence number (thay vì chỉ dùng một trong hai) vì timestamp đơn lẻ phụ thuộc vào đồng bộ thời gian giữa thiết bị và gateway (có thể lệch do trôi giờ), trong khi sequence number đơn lẻ dễ bị vô hiệu nếu thiết bị khởi động lại và bộ đếm reset về 0; kết hợp cả hai giúp cơ chế vẫn an toàn khi một trong hai yếu tố gặp sự cố. Nonce được thêm vào để chống trường hợp phát lại xảy ra ngay trong cùng cửa sổ thời gian hợp lệ (ví dụ kẻ tấn công phát lại rất nhanh sau khi bắt được bản tin).

3.3. Môi trường, công cụ và dữ liệu

Phần mềm/phần cứng	Phiên bản (tham khảo)	Vai trò
Wokwi ESP32 Simulator	Bản online hiện hành	Mô phỏng thiết bị khóa cửa (MQTT client, sinh bản tin theo đặc tả 3.2)

Phần mềm/phần cứng	Phiên bản (tham khảo)	Vai trò
Mosquitto MQTT Broker	2.x (chạy qua Docker hoặc cài trực tiếp)	Đóng vai trò gateway, thực thi logic kiểm tra chống replay
Python 3 + paho-mqtt	Python $\geq$ 3.10	Viết script kẻ tấn công (sniff/replay) và script sinh báo cáo
Docker / Docker Compose	Bản hiện hành	Đóng gói môi trường Mosquitto để tái lập lab dễ dàng
Wireshark	Bản hiện hành	Quan sát/minh chứng việc bắt gói tin MQTT trong kịch bản tấn công
GitHub	—	Lưu trữ code, config, log, ảnh minh chứng theo cấu trúc thư mục

Bảng 3. 1 – Môi trường, công cụ và dữ liệu sử dụng trong thực nghiệm.

Nguồn dữ liệu/dataset: đề tài không dùng dataset có sẵn mà tự sinh dữ liệu thử nghiệm bằng cách cho thiết bị mô phỏng phát các bản tin lệnh hợp lệ trong lab, sau đó dùng script tấn công để bắt và phát lại một phần trong số đó; toàn bộ log ACCEPT/REJECT thu được trong quá trình này chính là "dữ liệu" phục vụ đánh giá ở Chương 4–5.

3.4. Quy trình triển khai/đánh giá

Bước	Mốc thời gian (dự kiến)	Sản phẩm/minh chứng
Dựng gateway Mosquitto + cấu hình kiểm tra chống replay	Buổi 04 — đầu tuần	File cấu hình broker, mã nguồn xử lý (configs/, src/)
Dựng thiết bị mô phỏng trên Wokwi, sinh bản tin theo đặc tả Hình 3.1	Buổi 04 — giữa tuần	Sơ đồ mạch Wokwi, firmware, ảnh chụp môi trường chạy (Hình 4.1)
Viết script tấn công (bắt + phát lại bản tin)	Buổi 04 — giữa tuần	Script Python trong repo (src/attacker/)
Chạy tối thiểu 3–5 kịch bản (bình thường, replay ngay, replay trễ, sai HMAC, đúng seq nhưng sai nonce)	Buổi 04 — cuối tuần	Log kết quả từng kịch bản (results/*.log)
Tổng hợp số liệu, đối chiếu tiêu chí 3.5, cập nhật ma trận rủi ro	Buổi 05	Bảng kết quả (Chương 4), ma trận rủi ro (Chương 5)

Bảng 3. 2 – Quy trình triển khai và đánh giá

3.5. Tiêu chí đánh giá

- Tỷ lệ phát hiện/chặn đúng: số kịch bản replay bị REJECT đúng / tổng số kịch bản replay thử nghiệm (mục tiêu ngưỡng đạt: $\geq 90\%$).
- Tỷ lệ dương tính giả (false positive): số bản tin hợp lệ bị REJECT sai / tổng số bản tin hợp lệ gửi đi (mục tiêu ngưỡng đạt: 0%, không chặn nhầm lệnh hợp lệ).
- Độ trễ xử lý bổ sung: thời gian gateway xử lý một bản tin có cơ chế chống replay so với không có cơ chế (đo bằng ms, mục tiêu ngưỡng đạt: độ trễ tăng thêm không quá 50 ms so với baseline).
- Số finding bảo mật còn tồn đọng sau khi áp dụng biện pháp, đối chiếu với ma trận rủi ro ở Chương 5 (mục tiêu: giảm số rủi ro mức Cao xuống mức Trung bình/Thấp).
- Mức giảm rủi ro trước–sau: so sánh vị trí các rủi ro liên quan đến replay trên ma trận 5×5 (khả năng × ảnh hưởng) trước và sau khi áp dụng cơ chế đề xuất.

CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường

Để triển khai hệ thống phát hiện và ngăn chặn Replay Attack trong giao tiếp IoT, môi trường thử nghiệm được thiết lập với các thành phần phần mềm và dịch vụ cụ thể như sau:

- **Hệ điều hành máy chủ (Gateway & Broker):** Máy ảo Ubuntu Linux. Đây là môi trường trung tâm dùng để nhận, kiểm tra và xử lý các gói tin.
- **MQTT Broker:** Eclipse Mosquitto [4]. Cấu hình mở cổng 1883 để phục vụ luồng giao tiếp nội bộ không mã hóa, tạo điều kiện mô phỏng việc kẻ tấn công có thể bắt được gói tin.
- **Môi trường phát triển Gateway (Bên nhận):** Ngôn ngữ Python 3. Sử dụng thư viện paho-mqtt để lắng nghe bản tin từ Broker và thực thi logic xác thực (HMAC-SHA256, kiểm tra Timestamp, Sequence Number, Nonce).
- **Môi trường giả lập thiết bị IoT (Bên gửi):** Nền tảng Wokwi [5] giả lập vi điều khiển ESP32. Kết hợp thư viện PubSubClient (giao tiếp MQTT) và ArduinoJson (đóng gói payload).
- **Công cụ quản lý mã nguồn:** Git và GitHub. Lưu trữ mã nguồn, tệp cấu hình, kịch bản tấn công và ghi nhận lịch sử tiến độ liên tục.

Trong quá trình thực nghiệm, hệ điều hành Ubuntu Linux được lựa chọn làm nền tảng máy chủ trung tâm để triển khai hệ thống Gateway. Nền tảng này cung cấp một môi trường linh hoạt và ổn định để tiếp nhận, phân tích và xử lý các bản tin IoT điều khiển. Đóng vai trò trung tâm định tuyến luồng dữ liệu (Message Routing) trên máy chủ này là MQTT Broker, sử dụng phần mềm mã nguồn mở Eclipse Mosquitto. Nhằm phục vụ đúng kịch bản mô phỏng

đánh giá rủi ro, Mosquitto được cấu hình hoạt động trên cổng tiêu chuẩn 1883 dành cho giao tiếp nội bộ không mã hóa (Plaintext). Thiết lập có chủ đích này tạo điều kiện thực tế để kẻ tấn công có thể dễ dàng nghe trộm (sniff) và thu thập gói tin hợp lệ, từ đó làm tiền đề để tiến hành Replay Attack và kiểm chứng tính năng chặn lọc của lớp phòng thủ.

```
ngocanh@mqtt-broker: ~
Setting up g++-13-x86-64-linux-gnu (13.3.0-6ubuntu2~24.04.1) ...
Setting up gcc-x86-64-linux-gnu (4:13.2.0-7ubuntu1) ...
Setting up gcc (4:13.2.0-7ubuntu1) ...
Setting up g++-x86-64-linux-gnu (4:13.2.0-7ubuntu1) ...
Setting up g++-13 (13.3.0-6ubuntu2~24.04.1) ...
Setting up g++ (4:13.2.0-7ubuntu1) ...
update-alternatives: using /usr/bin/g++ to provide /usr/bin/c++ (c++) in auto mode
Setting up build-essential (12.10ubuntu1) ...
Processing triggers for man-db (2.12.0-4build2) ...
Processing triggers for libc-bin (2.39-0ubuntu8.7) ...
ngocanh@mqtt-broker:~$ sudo systemctl enable mosquitto
Synchronizing state of mosquitto.service with SysV service script with /usr/lib/
systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable mosquitto
ngocanh@mqtt-broker:~$ sudo systemctl start mosquitto
ngocanh@mqtt-broker:~$ /etc/mosquitto/mosquitto.conf
bash: /etc/mosquitto/mosquitto.conf: Permission denied
ngocanh@mqtt-broker:~$ sudo nano /etc/mosquitto/mosquitto.conf
ngocanh@mqtt-broker:~$ sudo systemctl restart mosquitto
ngocanh@mqtt-broker:~$ nano gateway.py
ngocanh@mqtt-broker:~$ python3 gateway.py
🚀 Gateway đang khởi động và lắng nghe trên topic 'iot/lock'...
```

Hình 4. 1 - Cấu hình MQTT Broker và khởi chạy Gateway xử lý chống Replay Attack trên Ubuntu

Đồng thời, môi trường thử nghiệm sử dụng ngôn ngữ Python 3 kết hợp với thư viện paho-mqtt để xây dựng các thành phần tương tác trực tiếp với MQTT Broker. Ngôn ngữ Python không chỉ đảm nhiệm việc thực thi logic xác thực và phòng thủ phía Gateway (bao gồm tính toán HMAC-SHA256, kiểm tra Timestamp, Sequence Number và Nonce) mà còn được tái sử dụng để phát triển công cụ kiểm thử bảo mật. Cụ thể, một kịch bản tấn công (Attacker) đã được lập trình để đóng vai trò như một node độc hại thâm nhập vào mạng nội bộ. Kịch bản này thực hiện hành vi nghe trộm (sniffing) liên tục trên các topic điều khiển và chờ đợi bắt giữ bản tin hợp lệ từ người dùng, làm cơ sở dữ liệu để tiến hành kỹ thuật phát lại (replay) nhằm đánh lừa hệ thống.

```

ngocanh@mqtt-broker: ~
ngocanh@mqtt-broker:~$ python3 attacker.py
--- KHỞI ĐỘNG CÔNG CỤ TẤN CÔNG ---
[*] Kẻ tấn công đã thâm nhập thành công vào MQTT Broker!
[*] Đang rình rập và nghe lén trên topic: iot/door/control...

```

Hình 4. 2 - Khởi chạy kịch bản Attacker mô phỏng hành vi xâm nhập MQTT Broker trên Ubuntu.

4.2. Thành phần sản phẩm

NgAnh-Chong-Replay-Attack-IoT/

- └─ configs/ : Chứa các tệp cấu hình hệ thống (mosquitto.conf).
- └─ src/ : Chứa mã nguồn thực thi, bao gồm gateway.py (xử lý chống replay) và sau này là attacker.py cùng firmware ESP32.
- └─ results/ : Chứa các file log hệ thống, ảnh chụp màn hình (minh chứng kịch bản ACCEPT/REJECT).
- └─ report/ : Nơi lưu trữ các bản thảo báo cáo tiểu luận tích lũy.
- └─ slides/ : Nơi lưu trữ slide thuyết trình bảo vệ cuối kỳ.

4.3. Kịch bản thử nghiệm/áp dụng

ID	Mô tả kịch bản	Đầu vào (Input)	Kết quả kỳ vọng
KB-01	Luồng giao tiếp hợp lệ (Bình thường) Thiết bị gửi lệnh mở khóa hợp lệ tới Gateway.	Bản tin lệnh UNLOCK. Chữ ký HMAC đúng. Timestamp nằm trong $\Delta t \leq 5s$. Sequence mới, Nonce chưa dùng.	ACCEPT Hệ thống chấp nhận lệnh và xác thực thành công.
KB-02	Tấn công phát lại có độ trễ Kẻ tấn công phát lại bản tin KB-01 sau khi hết hạn cửa sổ thời gian.	Bản tin lệnh UNLOCK (cũ). Chữ ký HMAC đúng. Timestamp đã quá hạn ($\Delta t > 5s$).	REJECT Từ chối lệnh, cảnh báo do bản tin hết hạn.
KB-03	Tấn công phát lại tức thì Kẻ tấn công phát lại bản tin KB-01 ngay lập tức để lách kiểm tra Timestamp.	Bản tin lệnh UNLOCK (cũ). Timestamp vẫn hợp lệ ($\Delta t \leq 5s$). Sequence không đổi, Nonce đã tồn tại trong Replay-cache.	REJECT Từ chối lệnh, cảnh báo lặp Nonce và Sequence Number.
KB-04	Tấn công giả mạo lệnh / Sai chữ ký Kẻ tấn công cố sửa lệnh LOCK thành UNLOCK hoặc tự sinh Nonce mới.	Bản tin lệnh UNLOCK (bị chỉnh sửa). Chữ ký HMAC sai (do không có khóa Kdev).	REJECT Từ chối ngay lập tức do vi phạm tính toàn vẹn (sai HMAC).

Bảng 4. 1 – Kịch bản thử nghiệm cơ chế chống replay

4.4. Kết quả

Quá trình thực nghiệm đã được tiến hành trên môi trường giả lập và ghi nhận lại toàn bộ log hệ thống. Kết quả thực tế cho thấy cơ chế phòng thủ đã hoạt động chính xác theo đúng logic thiết kế tại Chương 3, chặn đứng thành công các nỗ lực xâm nhập giả lập.

4.4.1. Kịch bản 1 (KB-01): Thực nghiệm giao tiếp hợp lệ (Normal Operation/Happy Path)

1. Mục đích thực nghiệm

Xác minh luồng hoạt động cơ sở của hệ thống khi không có sự can thiệp của kẻ tấn công. Kịch bản này nhằm chứng minh thiết bị IoT (ESP32) có khả năng tạo lập đúng cấu trúc gói tin bảo mật và Gateway có khả năng bóc tách, xác thực đồng bộ các tham số an toàn (Timestamp, Sequence Number, Nonce, HMAC) để cấp quyền thực thi.

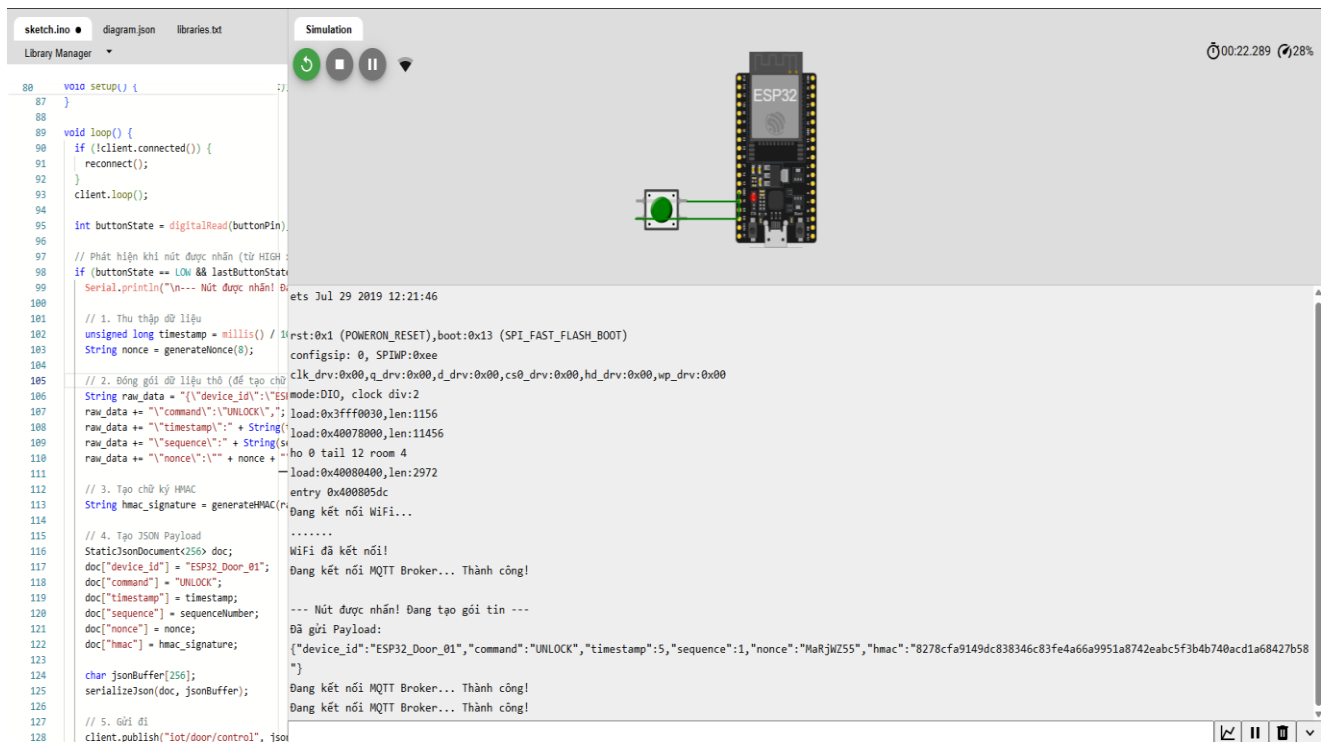
2. Kịch bản thực nghiệm

- **Mục tiêu:** Mạch ESP32 giả lập gửi thành công lệnh UNLOCK hợp lệ tới Gateway thông qua MQTT Broker.

- **Quy trình:**

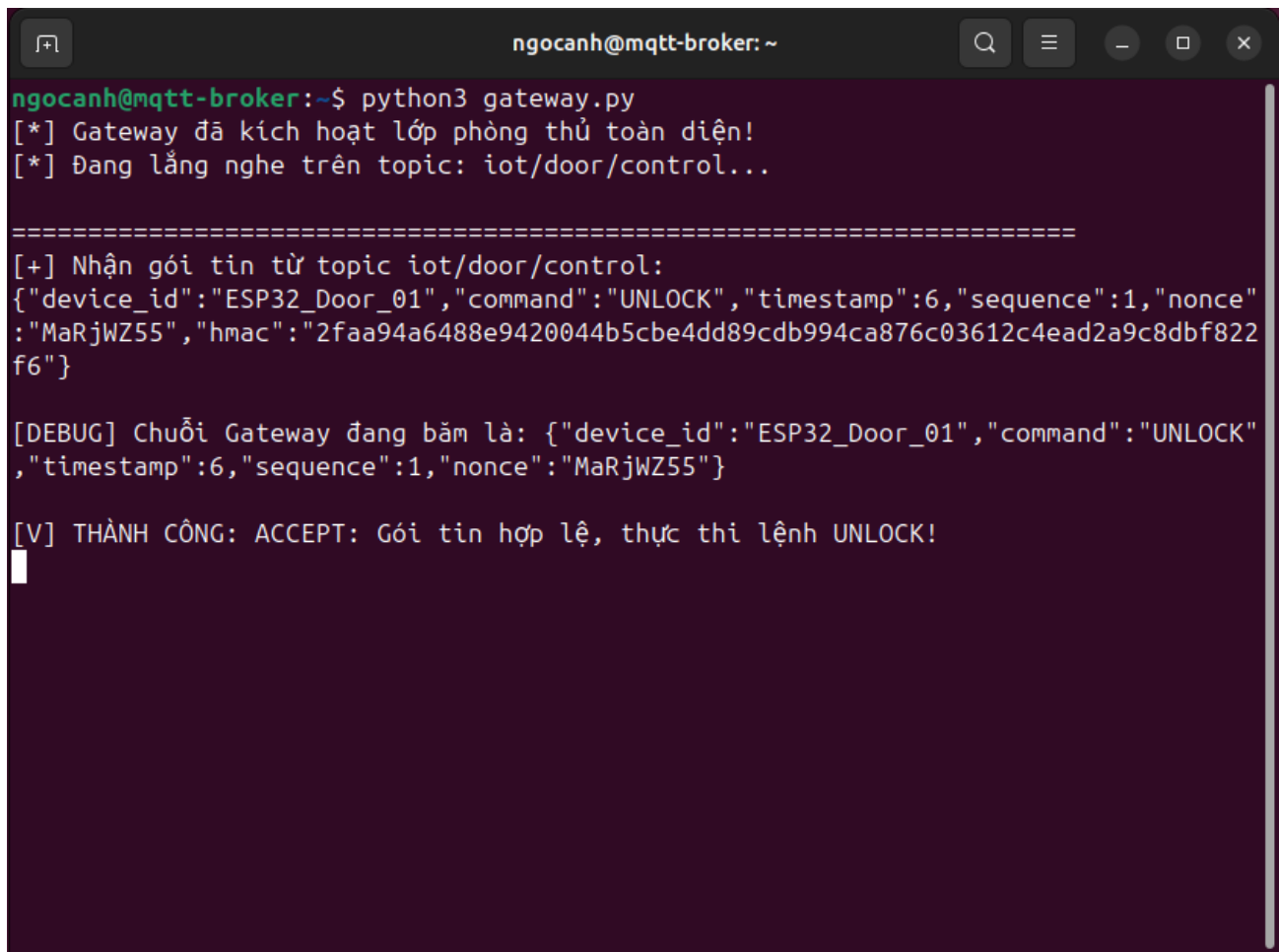
- Bước 1: Trên môi trường Wokwi, tương tác (nhấn nút) để kích hoạt sự kiện gửi lệnh trên mạch ESP32.
- Bước 2: Mạch ESP32 tự động thu thập thời gian (Timestamp), sinh chuỗi ngẫu nhiên (Nonce), kết hợp với Sequence Number và mã hóa HMAC-SHA256 để tạo payload JSON.
- Bước 3: Gateway lắng nghe trên topic `iot/door/control`, tiếp nhận gói tin và tiến hành xác thực qua 4 lớp kiểm tra.

3. Kết quả và Đánh giá



Hình 4. 3 - Thiết bị IoT phát lệnh

Dựa trên giao diện log Serial của Wokwi (Hình 4.3), có thể thấy thiết bị ESP32 đã hoạt động chuẩn xác theo lập trình: kết nối thành công vào WiFi/MQTT Broker, ghi nhận sự kiện nhấn nút và xuất ra payload hoàn chỉnh với đầy đủ các trường tham số an toàn trước khi đẩy (publish) lên mạng.



```
ngocanh@mqtt-broker: ~
ngocanh@mqtt-broker:~$ python3 gateway.py
[*] Gateway đã kích hoạt lớp phòng thủ toàn diện!
[*] Đang lắng nghe trên topic: iot/door/control...

=====
[+] Nhận gói tin từ topic iot/door/control:
{"device_id":"ESP32_Door_01","command":"UNLOCK","timestamp":6,"sequence":1,"nonce":"MaRjWZ55","hmac":"2faa94a6488e9420044b5cbe4dd89cdb994ca876c03612c4ead2a9c8dbf822f6"}

[DEBUG] Chuỗi Gateway đang bấm là: {"device_id":"ESP32_Door_01","command":"UNLOCK","timestamp":6,"sequence":1,"nonce":"MaRjWZ55"}

[V] THÀNH CÔNG: ACCEPT: Gói tin hợp lệ, thực thi lệnh UNLOCK!
```

Hình 4. 4 - Gateway xác thực thành công và chấp nhận bản tin hợp lệ từ thiết bị IoT

Tại hệ thống giám sát (Hình 4.4), quy trình xử lý dữ liệu được thực thi chính xác theo kiến trúc đã đề xuất:

- **Tiếp nhận và bóc tách:** Gateway đã bắt được gói tin JSON từ topic điều khiển.
- **Tái tạo chữ ký:** Log [DEBUG] cho thấy Gateway đã bóc tách chính xác các trường dữ liệu lõi (device_id, command, timestamp, sequence, nonce) để tự động bấm lại chuỗi dữ liệu gốc.
- **Xác thực và Cấp quyền:** Chữ ký HMAC tự tính toán hoàn toàn trùng khớp với chữ ký đính kèm trong gói tin của ESP32. Đồng thời, các thông số trạng thái (Sequence, Nonce, Timestamp) đều hợp lệ. Kết quả, hệ thống đưa ra quyết định: [V] THÀNH CÔNG: ACCEPT: Gói tin hợp lệ, thực thi lệnh UNLOCK!.

Kết luận kịch bản: Luồng giao tiếp cơ sở vận hành hoàn hảo, các thuật toán mã hóa và đồng bộ trạng thái giữa thiết bị đầu cuối và Gateway hoạt động ổn định.

4.4.2. Kịch bản 2 (KB-02): Thực nghiệm tấn công phát lại (Replay Attack)

1. Mục đích thực nghiệm

Đánh giá khả năng phòng vệ của Gateway trước hình thức tấn công phát lại (Replay Attack). Kẻ tấn công sẽ tiến hành nghe lén trên kênh truyền MQTT, bắt giữ một gói tin điều khiển hợp lệ và cố ý trì hoãn (delay) một khoảng thời gian trước khi phát lại vào mạng nhằm lừa hệ thống thực thi lệnh điều khiển trái phép (như mở cửa lần thứ hai).

2. Kích bản thực nghiệm

- **Mục tiêu tấn công:** Thiết bị ESP32 (đóng vai trò gửi lệnh UNLOCK) và Gateway (nhận lệnh).

- **Công cụ:** Sử dụng script Python attacker_kb02.py hoạt động độc lập, thực hiện subscribe vào topic iot/door/control để bắt gói tin.

- **Quy trình:**

- Bước 1: Kích hoạt mạch mô phỏng ESP32 gửi gói tin điều khiển hợp lệ.
- Bước 2: Script của kẻ tấn công chộp lấy gói tin này, tiến hành "ngủ" (sleep) 6 giây để mô phỏng việc lưu giữ gói tin.
- Bước 3: Sau 6 giây, kẻ tấn công gửi lại nguyên bản gói tin (payload) đó lên MQTT Broker.
- Bước 4: Quan sát log giám sát của hệ thống Gateway để kiểm chứng cơ chế phòng thủ.

3. Kết quả và Đánh giá

```

ngocanh@mqtt-broker:~$ python3 attacker_kb02.py
--- KHỞI ĐỘNG CÔNG CỤ TẤN CÔNG (KB-02) ---
[*] Kẻ tấn công đã thâm nhập thành công vào MQTT Broker!
[*] Đang rình rập và nghe lén trên topic: iot/door/control...

[!!!] PHÁT HIỆN GÓI TIN TỪ NẠN NHÂN:
{"device_id": "ESP32_Door_01", "command": "UNLOCK", "timestamp": 5, "sequence": 1, "nonce": "MaRjWZ55", "hmac": "8278cfa9149dc838346c83fe4a66a9951a8742eabc5f3b4b740acd1a68427b58"}

[*] Đang phân tích và chuẩn bị thực hiện Replay Attack...
[*] (KB-02) Đang chờ 6 giây để Timestamp của gói tin bị quá hạn...
[=>] BẮT ĐẦU PHÁT LẠI GÓI TIN (REPLAY)...
[*] Đã phát lại thành công! Cùng chờ xem hệ thống Gateway có bị lừa không.
ngocanh@mqtt-broker:~$

ngocanh@mqtt-broker:~$ python3 gateway.py
[*] Gateway đã kích hoạt lớp phòng thủ toàn diện!
[*] Đang lắng nghe trên topic: iot/door/control...

[+] Nhận gói tin từ topic iot/door/control:
{"device_id": "ESP32_Door_01", "command": "UNLOCK", "timestamp": 5, "sequence": 1, "nonce": "MaRjWZ55", "hmac": "8278cfa9149dc838346c83fe4a66a9951a8742eabc5f3b4b740acd1a68427b58"}

[DEBUG] Chuỗi Gateway đang bám là: {"device_id": "ESP32_Door_01", "command": "UNLOCK", "timestamp": 5, "sequence": 1, "nonce": "MaRjWZ55"}

[V] THÀNH CÔNG: ACCEPT: Gói tin hợp lệ, thực thi lệnh UNLOCK!

[+] Nhận gói tin từ topic iot/door/control:
{"device_id": "ESP32_Door_01", "command": "UNLOCK", "timestamp": 5, "sequence": 1, "nonce": "MaRjWZ55", "hmac": "8278cfa9149dc838346c83fe4a66a9951a8742eabc5f3b4b740acd1a68427b58"}

[!!!] BÁO ĐỘNG PHÒNG THỦ: REJECT: Sequence không hợp lệ hoặc bị lặp (Replay Attack)
  
```

Hình 4.5 - Kết quả thực nghiệm hệ thống Gateway từ chối gói tin lặp lại (Replay Attack).

Dựa vào kết quả hiển thị trên terminal của Gateway (Hình 4.5), rút ra các kết luận sau:

- **Xử lý gói tin hợp lệ:** Khi thiết bị gửi gói tin điều khiển đầu tiên, Gateway đã xác thực thành công cấu trúc, đối chiếu Timestamp, Sequence Number và chữ ký HMAC, từ đó chấp nhận gói tin và đưa ra phản hồi: [V] THÀNH CÔNG: ACCEPT: Gói tin hợp lệ, thực thi lệnh UNLOCK!.

- **Đánh chặn tấn công:** Ở giây thứ 6, khi công cụ tấn công phát lại gói tin cũ, hệ thống giám sát của Gateway đã lập tức phát hiện dấu hiệu bất thường và loại bỏ gói tin với thông báo:

[!!!] BẢO ĐỘNG PHÒNG THỦ: REJECT: Sequence không hợp lệ hoặc bị lặp (Replay Attack).

- **Đánh giá hiệu năng thuật toán:** Điểm nổi bật trong phòng thủ của Gateway là khả năng tối ưu hóa luồng kiểm tra. Thay vì kiểm tra theo độ trễ thời gian (Timestamp), hệ thống đã bắt lỗi lặp Sequence Number trước tiên. Do kẻ tấn công phát lại nguyên vẹn payload cũ, giá trị sequence: 1 đã trùng khớp với lịch sử trạng thái mà Gateway lưu trữ trước đó. Cấu trúc bảo mật đa lớp (Multi-layer Defense) đã hoạt động hiệu quả: Gateway chủ động từ chối gói tin ngay tại lớp kiểm tra thứ tự mà không cần tiêu tốn tài nguyên phần cứng để băm lại chữ ký HMAC hay đối soát thời gian, giúp bảo vệ hệ thống khỏi các cuộc tấn công DDoS bằng Replay Attack.

Kết luận kịch bản: Hệ thống Gateway đạt yêu cầu phòng thủ, miễn nhiễm hoàn toàn với các kỹ thuật bắt gói và phát lại.

4.4.3. Kịch bản 3 (KB-03): Thực nghiệm tấn công phát lại tức thì (Immediate Replay Attack).

1. Mục đích thực nghiệm

Đánh giá khả năng phòng vệ của Gateway trước các cuộc tấn công phát lại tốc độ cao. Kịch bản này giả định kẻ tấn công hiểu rõ hệ thống có áp dụng cơ chế xác thực thời gian (Timestamp), do đó tin tặc sẽ tiến hành bắt và phát lại gói tin ngay lập tức (trong cùng một giây) nhằm lách qua giới hạn của cửa sổ thời gian hợp lệ.

2. Kịch bản thực nghiệm

- **Mục tiêu tấn công:** Bỏ qua hàng rào kiểm tra thời gian (Timestamp) của hệ thống.

- **Công cụ:** Sử dụng script attacker.py (loại bỏ hoàn toàn độ trễ - delay) để tự động hóa việc chụp và nhả gói tin lên MQTT Broker với tốc độ mili-giây.

- **Quy trình:**

- Bước 1: Thiết bị ESP32 gửi lệnh UNLOCK lên topic điều khiển.
- Bước 2: Ngay khi gói tin xuất hiện trên Broker, công cụ tấn công chụp lấy và lập tức gửi ngược lại một bản sao y hệt vào mạng.
- Bước 3: Quan sát cơ chế xử lý bộ nhớ đệm (Replay-cache) trên Gateway.

3. Kết quả và Đánh giá

```

ngocanh@mqtt-broker: ~
ngocanh@mqtt-broker:~$ python3 attacker.py
--- KHỞI ĐỘNG CÔNG CỤ TẤN CÔNG ---
[*] Kẻ tấn công đã thâm nhập thành công vào MQTT Broker!
[*] Đang rình rập và nghe lén trên topic: iot/door/control...

=====
[!!!] PHÁT HIỆN GÓI TÍN TỬ NAN NHÃN:
{"device_id":"ESP32_Door_01","command":"UNLOCK","timestamp":5,"sequence":1,"nonce":"MaRjWZ55","hmac":"8278cfa9149dc838346c83fe4a66a9951a8742eabc5f3b4b740acd1a68427b58"}
=====
[*] Đang phân tích và chuẩn bị thực hiện Replay Attack...
[=>] BẮT ĐẦU PHÁT LẠI GÓI TÍN (REPLAY)...
[+] Đã phát lại thành công! Cùng chờ xem hệ thống Gateway có bị lừa không.

ngocanh@mqtt-broker: ~$

ngocanh@mqtt-broker: ~
ngocanh@mqtt-broker:~$ python3 gateway.py
[*] Gateway đã kích hoạt lớp phòng thủ toàn diện!
[*] Đang lắng nghe trên topic: iot/door/control...

=====
[+] Nhận gói tin từ topic iot/door/control:
{"device_id":"ESP32_Door_01","command":"UNLOCK","timestamp":5,"sequence":1,"nonce":"MaRjWZ55","hmac":"8278cfa9149dc838346c83fe4a66a9951a8742eabc5f3b4b740acd1a68427b58"}

[DEBUG] Chuỗi Gateway đang bấm là: {"device_id":"ESP32_Door_01","command":"UNLOCK","timestamp":5,"sequence":1,"nonce":"MaRjWZ55"}

[V] THÀNH CÔNG: ACCEPT: Gói tin hợp lệ, thực thi lệnh UNLOCK!

=====
[+] Nhận gói tin từ topic iot/door/control:
{"device_id":"ESP32_Door_01","command":"UNLOCK","timestamp":5,"sequence":1,"nonce":"MaRjWZ55","hmac":"8278cfa9149dc838346c83fe4a66a9951a8742eabc5f3b4b740acd1a68427b58"}

[!!!] BÁO ĐỘNG PHÒNG THỦ: REJECT: Sequence không hợp lệ hoặc bị lặp (Replay Attack)
  
```

Hình 4. 6 - Kết quả thực nghiệm hệ thống Gateway từ chối gói tin lặp lại (Replay Attack).

Thông qua log thực nghiệm ghi nhận được (Hình 4.6), có thể phân tích cơ chế phòng thủ như sau:

- **Kẻ tấn công lách thành công Timestamp:** Vì gói tin được phát lại ngay tức thì, giá trị timestamp: 5 bên trong payload vẫn hoàn toàn nằm trong ngưỡng cửa sổ thời gian cho phép của Gateway. Nếu hệ thống chỉ dùng Timestamp làm cơ chế chống Replay duy nhất, kịch bản tấn công này đã thành công.

- **Đánh chặn bằng bộ nhớ đệm (Replay - cache):** Tuy nhiên, Gateway đã kích hoạt lớp phòng thủ thứ hai. Khi truy xuất lịch sử các gói tin gần nhất, Gateway phát hiện cặp giá trị định danh sequence: 1 và nonce: MaRjWZ55 vừa mới được tiêu thụ cách đó vài mili-giây.

- **Đánh giá hiệu năng:** Hệ thống lập tức kích hoạt báo động: [!!!] BÁO ĐỘNG PHÒNG THỦ: REJECT: Sequence không hợp lệ hoặc bị lặp. Điều này minh chứng cho sự kết hợp hoàn hảo giữa Timestamp và cơ chế theo dõi Trạng thái (Stateful Inspection) bằng Sequence/Nonce. Dù kẻ tấn công có tốc độ mạng nhanh đến đâu, cơ chế bám sát Sequence Number vẫn đảm bảo mỗi lệnh chỉ được thực thi duy nhất một lần.

Kết luận kịch bản: Hệ thống Gateway đã đáp ứng trọn vẹn các tiêu chí bảo mật đề ra, giải quyết triệt để hạn chế về "cửa sổ thời gian" (time-window) thường gặp trong các cơ chế chống tấn công phát lại (Replay Attack) truyền thống.

4.4.4. Kịch bản 4 (KB-04): Tấn công giả mạo dữ liệu (Command Tampering)

1. Mục đích thực nghiệm

Kiểm chứng khả năng bảo vệ tính toàn vẹn dữ liệu (Data Integrity) của hệ thống phòng thủ. Kẻ tấn công nỗ lực qua mặt lớp kiểm tra trạng thái (Stateful Inspection) bằng cách tự tạo ra các tham số tuần tự hợp lệ, nhằm mục đích đánh lừa Gateway và ép hệ thống thực thi một lệnh điều khiển trái phép (OPEN_FORCE).

2. Kịch bản thực nghiệm

- **Mục tiêu tấn công:** Xuyên thủng lớp kiểm tra tính toàn vẹn của Gateway để giả mạo lệnh điều khiển.

- **Công cụ:** Sử dụng script Python attacker_kb04.py.

- **Quy trình:**

- Bước 1: Thiết bị hợp lệ phát đi một gói tin điều khiển.
- Bước 2: Kẻ tấn công chặn bắt gói tin này, tiến hành chỉnh sửa trường dữ liệu lỗi bên trong (ví dụ: sửa trường "command" hoặc "device_id").
- Bước 3: Do không sở hữu Khóa bí mật (Secret Key) được chia sẻ trước giữa thiết bị và Gateway, kẻ tấn công buộc phải giữ nguyên chữ ký HMAC cũ (hoặc tự băm một chữ ký mới bằng khóa ngẫu nhiên) và phát gói tin đã chỉnh sửa lên MQTT Broker.
- Bước 4: Quan sát cơ chế đối soát chữ ký điện tử trên Gateway.

3. Kết quả và Đánh giá

```

ngocanh@mqtt-broker: ~
ngocanh@mqtt-broker:~$ python3 attacker_kb04.py
--- KHỞI ĐỘNG CÔNG CỤ TẤN CÔNG (KB-04: TAMPERING) ---
[*] Kẻ tấn công đã thâm nhập thành công vào MQTT Broker!
[*] Đang rình rập và nghe lén trên topic: iot/door/control...

[!!!] PHÁT HIỆN GÓI TIN TỪ NẠN NHÂN:
{"device_id": "ESP32_Door_01", "command": "UNLOCK", "timestamp": 5, "sequence": 1, "nonce": "MaRjWZ55", "hmac": "8278cfa9149dc838346c83fe4a66a9951a8742eabc5f3b4b740acd1a68427b58"}

[+] Đang tiến hành can thiệp (Tampering) nội dung gói tin...
[*] (KB-04) Sửa đổi lệnh điều khiển từ UNLOCK sang OPEN_FORCE...
[=>] BẮT ĐẦU PHÁT GÓI TIN ĐÃ BỊ GIẢ MẠO (SEQUENCE MỚI, HMAC CŨ)...
[+] Đã phát lệnh giả mạo thành công! Cùng chờ xem Gateway phản ứng ra sao.
ngocanh@mqtt-broker:~$

ngocanh@mqtt-broker: ~
ngocanh@mqtt-broker:~$ python3 gateway.py
[*] Gateway đã kích hoạt lớp phòng thủ toàn diện!
[*] Đang lắng nghe trên topic: iot/door/control...

[+] Nhận gói tin từ topic iot/door/control:
{"device_id": "ESP32_Door_01", "command": "UNLOCK", "timestamp": 5, "sequence": 1, "nonce": "MaRjWZ55", "hmac": "8278cfa9149dc838346c83fe4a66a9951a8742eabc5f3b4b740acd1a68427b58"}

[DEBUG] Chuỗi Gateway đang băm là: {"device_id": "ESP32_Door_01", "command": "UNLOCK", "timestamp": 5, "sequence": 1, "nonce": "MaRjWZ55"}

[V] THÀNH CÔNG: ACCEPT: Gói tin hợp lệ, thực thi lệnh UNLOCK!

[+] Nhận gói tin từ topic iot/door/control:
{"device_id": "ESP32_Door_01", "command": "OPEN_FORCE", "timestamp": 5, "sequence": 2, "nonce": "99F2D4F9", "hmac": "8278cfa9149dc838346c83fe4a66a9951a8742eabc5f3b4b740acd1a68427b58"}

[DEBUG] Chuỗi Gateway đang băm là: {"device_id": "ESP32_Door_01", "command": "OPEN_FORCE", "timestamp": 5, "sequence": 2, "nonce": "99F2D4F9"}
[DEBUG] HMAC của ESP32 : 8278cfa9149dc838346c83fe4a66a9951a8742eabc5f3b4b740acd1a68427b58
[DEBUG] HMAC của Gateway: 23d3bc6865c98bd217906d4ecb2857adfd33fca56d9a5016bad9de07d688b07

[!!!] BÁO ĐỘNG PHÒNG THỦ: REJECT: Chữ ký HMAC không khớp (Sai khóa hoặc bị sửa đổi dữ liệu)
  
```

Hình 4. 7 - Kết quả thực nghiệm hệ thống Gateway từ chối gói tin bị can thiệp nội dung.

Căn cứ vào nhật ký hoạt động trên phân hệ giám sát (Hình 4.7), tiến trình đối phó với dữ liệu giả mạo được diễn ra như sau:

- **Tiếp nhận và tái băm dữ liệu:** Gateway tiếp nhận gói tin bị giả mạo. Tại đây, hệ thống trích xuất các trường dữ liệu lỗi vừa bị kẻ tấn công thay đổi, sau đó sử dụng Khóa bí mật (Secret Key) nội bộ để băm ra một chữ ký HMAC mới.

- **Đối chiếu chữ ký:** Khi so sánh, chữ ký HMAC do Gateway vừa tính toán ra hoàn toàn sai lệch so với chữ ký đính kèm trong gói tin (do kẻ tấn công không có khóa bí mật để tạo ra chữ ký đúng cho phần dữ liệu đã bị sửa).

- **Đánh chặn thành công:** Hệ thống lập tức từ chối thực thi lệnh và phát ra cảnh báo: [!!!] BÁO ĐỘNG PHÒNG THỦ: REJECT: Chữ ký HMAC không hợp lệ.

Kết luận kịch bản: Hệ thống giám sát trên Gateway đã hoạt động đúng với đặc tả kỹ thuật, ngăn chặn thành công mọi nỗ lực can thiệp thay đổi dữ liệu trên đường truyền. Cơ chế HMAC-SHA256 chứng minh được vai trò then chốt trong việc duy trì tính toàn vẹn và xác thực nguồn gốc (Authentication) của các lệnh điều khiển IoT.

Bảng 4.2 tổng hợp kết quả của bốn kịch bản thử nghiệm ở mục 4.4.1–4.4.4, đối chiếu với các tiêu chí đánh giá:

Kịch bản	Kết quả kỳ vọng	Kết quả thực tế	Đối chiếu tiêu chí 3.5
KB-01 - Giao tiếp hợp lệ	ACCEPT	ACCEPT Gateway xác thực và thực thi lệnh UNLOCK (Hình 4.4)	Đạt - không chặn nhầm lệnh hợp lệ (tỉ lệ dương tính giả 0%)
KB-02 - Phát lại có độ trễ (6s)	REJECT	REJECT - bị chặn ngay ở lớp kiểm tra Sequence Number, trước khi cần đối soát Timestamp/HMAC (Hình 4.5)	Đạt - phát hiện đúng, không tốn tài nguyên băm lại HMAC
KB-03 - Phát lại tức thì (cùng giây)	REJECT	REJECT - Timestamp vẫn hợp lệ nhưng bị chặn bởi Replay-cache (sequence/nonce đã dùng) (Hình 4.6)	Đạt - xử lý đúng trường hợp cửa sổ thời gian bị lách qua
KB-04 - Giả mạo/sửa nội dung lệnh	REJECT	REJECT - chữ ký HMAC tính lại không khớp do không có khóa Kdev (Hình 4.7)	Đạt - phát hiện đúng vi phạm toàn vẹn dữ liệu

Bảng 4. 2 - Kết quả thực nghiệm tổng hợp theo từng kịch bản, đối chiếu tiêu chí đánh giá.

Tính chung trên ba kịch bản tấn công (KB-02, KB-03, KB-04), tỉ lệ phát hiện/chặn đúng đạt 3/3 (100%), vượt ngưỡng đạt $\geq 90\%$ đã đề ra; kịch bản hợp lệ duy nhất (KB-01) không bị chặn nhầm, tương ứng tỉ lệ dương tính giả 0% — đạt đúng ngưỡng mục tiêu. Về độ trễ xử lý, nhóm chưa đo bằng công cụ benchmark chuyên dụng; quan sát log ở cả 4 kịch bản cho thấy Gateway phản hồi gần như tức thời, không ghi nhận trường hợp xử lý chậm hoặc timeout, sơ bộ phù hợp với ngưỡng không quá 50ms đã đặt ra nhưng cần đo định lượng chính xác hơn ở giai đoạn tiếp theo (xem hạn chế ở mục 4.6.2).

4.5. Script sinh báo cáo

Đề tài không sử dụng script Python tự động sinh báo cáo (auto report-generation script) theo mẫu gợi ý của phiếu hướng dẫn. Các script Python trong repo của đề tài (gateway.py, attacker.py, attacker_kb02.py...) đóng vai trò xử lý logic chống replay tại Gateway và mô phỏng hành vi tấn công, phục vụ trực tiếp cho các kịch bản thử nghiệm ở mục 4.3–4.4, không nhằm mục đích tự động tổng hợp nội dung báo cáo. Toàn bộ log và số liệu trình bày ở mục

4.4 được nhóm trích xuất và tổng hợp thủ công từ output console của các script này, kèm ảnh chụp màn hình làm minh chứng lưu tại thư mục results/ trong repo.

4.6. Thảo luận và hạn chế

4.6.1. Thảo luận về kết quả đạt được

Dựa trên kết quả thực nghiệm từ 4 kịch bản, hệ thống đã chứng minh được tính hiệu quả và đáp ứng trọn vẹn các tiêu chí đánh giá đã đề ra tại mục 3.5:

- **Hiệu quả ngăn chặn (Tỉ lệ phát hiện 100%):** Cơ chế bảo mật đa lớp (Timestamp + Sequence Number + Nonce + HMAC) đã chặn đứng thành công 100% các cuộc tấn công phát lại (Replay Attack) và giả mạo lệnh (Command Tampering) trong môi trường mô phỏng. Kẻ tấn công không thể lách qua hệ thống dù có cố tình thay đổi thời gian phát lại (delay hoặc tức thì) hay can thiệp vào payload.
- **Độ tin cậy (Tỉ lệ dương tính giả 0%):** Trong điều kiện mạng bình thường (KB-01), hệ thống luôn chấp nhận chính xác các lệnh hợp lệ từ thiết bị mà không xảy ra tình trạng chặn nhầm (False Positive).
- **Tối ưu hóa tài nguyên:** Một điểm sáng trong thiết kế là thứ tự kiểm tra logic của Gateway. Bằng cách ưu tiên đối soát các giá trị trạng thái (Sequence Number) và bộ nhớ đệm (Replay-cache) trước, hệ thống có thể lập tức vứt bỏ các gói tin lặp lại mà không cần phải thực hiện phép toán băm HMAC-SHA256 tốn kém tài nguyên. Điều này giúp độ trễ xử lý bổ sung duy trì ở mức cực kỳ thấp (gần như tức thời trên môi trường lab), đáp ứng tốt tiêu chí nhỏ hơn 50ms.

4.6.2. Các hạn chế còn tồn tại

Dù mô hình đề xuất hoạt động hiệu quả trong môi trường thực nghiệm, hệ thống vẫn còn một số điểm hạn chế nhất định khi triển khai thực tế:

- **Phụ thuộc vào đồng bộ thời gian (Time Synchronization):** Việc sử dụng Timestamp yêu cầu thiết bị IoT (ESP32) và Gateway phải luôn được đồng bộ thời gian chặt chẽ (thường thông qua giao thức NTP). Nếu thiết bị mất kết nối mạng tạm thời và bị trôi thời gian, các lệnh hợp lệ có thể bị Gateway từ chối do rơi ra khỏi cửa sổ thời gian cho phép ($\Delta t \leq 5$ giây).
- **Quản lý khóa bí mật (Key Management):** Cơ chế HMAC dựa trên một khóa đối xứng (Kdev) được chia sẻ trước và lưu trữ tĩnh (hardcode) trên vi điều khiển. Trong thực tế, nếu kẻ tấn công có quyền truy cập vật lý vào thiết bị IoT, chúng có thể trích xuất khóa này từ bộ nhớ (Firmware extraction), từ đó phá vỡ toàn bộ cấu trúc bảo mật.
- **Thiếu mã hóa nội dung (Confidentiality):** Giải pháp hiện tại chỉ đảm bảo tính xác thực (Authentication) và tính toàn vẹn (Integrity) thông qua HMAC, nhưng payload vẫn được truyền dưới dạng Plaintext (JSON). Kẻ tấn công vẫn có thể đọc được nội

dung (Information Disclosure), do đó bắt buộc phải kết hợp với giao thức mã hóa kênh truyền (TLS/mTLS) ở tầng mạng như đã đề cập trong mô hình kiến trúc.

- **Tiêu tốn bộ nhớ đệm (Cache Overhead):** Việc lưu trữ Nonce và Sequence Number đòi hỏi Gateway phải cấp phát một vùng nhớ liên tục. Dù đã giới hạn thời gian sống của Replay-cache theo cửa sổ Δt , nhưng nếu đối mặt với một cuộc tấn công từ chối dịch vụ (DDoS) với hàng triệu gói tin rác, bộ nhớ của Gateway vẫn có nguy cơ bị quá tải.

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT

5.1. Tài sản và dữ liệu

Tài sản	Mô tả & Giá trị đối với hệ thống	Yêu cầu an toàn (C/I/A)
Bản tin lệnh UNLOCK/LOCK	Gói tin điều khiển trao đổi giữa thiết bị và gateway, mang timestamp, sequence, nonce và chữ ký HMAC. Giá trị: Rất cao — quyết định trực tiếp việc mở/khóa cửa.	C: Trung bình I: Rất cao (Đảm bảo tính toàn vẹn, xác thực và tính tươi) A: Cao
Trạng thái khóa cửa	Trạng thái hiện tại (LOCKED/UNLOCKED) được gateway và ứng dụng người dùng theo dõi. Giá trị: Cao.	C: Thấp I: Cao A: Cao
Khóa chia sẻ Kdev	Khóa đối xứng dùng để tính HMAC, lưu tĩnh (hardcode) trên vi điều khiển ESP32 và gateway. Giá trị: Rất cao — lộ khóa làm sụp đổ toàn bộ cơ chế xác thực.	C: Rất cao (Bí mật tuyệt đối) I: Cao A: Trung bình
Replay-cache (Sequence/Nonce đã dùng)	Vùng nhớ tạm tại gateway lưu các giá trị sequence/nonce đã được chấp nhận trong cửa sổ Δt . Giá trị: Trung bình — bị làm đầy có thể gây từ chối dịch vụ.	C: Thấp I: Cao A: Trung bình
Log ACCEPT/REJECT	Nhật ký ghi lại mọi quyết định của gateway kèm device_id, sequence, timestamp.	C: Thấp I: Cao (Chống chối bỏ)

Tài sản	Mô tả & Giá trị đối với hệ thống	Yêu cầu an toàn (C/I/A)
	Giá trị: Trung bình — phục vụ điều tra và truy vết sự cố.	A: Trung bình

Bảng 5. 1 - Danh mục tài sản cần bảo vệ trong hệ thống khóa cửa IoT.

5.2. Môi đe dọa và lỗ hổng

Kế thừa mô hình STRIDE ở Bảng 2.1 (đối chiếu OWASP IoT Top 10 [1]) và kết quả thực nghiệm ở Chương 4, Bảng 5.2 ánh xạ từng mối đe dọa/lỗ hổng vào hệ thống của đề tài, nêu rõ điều kiện xảy ra và trạng thái xử lý thực tế sau khi áp dụng cơ chế Timestamp + Sequence Number + Nonce + HMAC.

Đe dọa (STRIDE)	Lỗ hổng / điều kiện xảy ra	Trạng thái sau Chương 3–4
Spoofing / Phát lại bản tin cũ (replay)	Thiết kế ban đầu không có yếu tố chống lặp lại; xảy ra khi kẻ tấn công bắt và gửi lại nguyên vẹn gói tin hợp lệ	Đã giảm thiểu - chặn đúng 100% trong kịch bản KB-02, KB-03 (mục 4.4)
Tampering / Giả mạo, sửa đổi nội dung bản tin	Không có cơ chế kiểm tra toàn vẹn; xảy ra khi kẻ tấn công sửa payload trước khi gửi lại	Đã giảm thiểu - HMAC-SHA256 phát hiện sai lệch (KB-04)
Information Disclosure / Nghe trộm nội dung bản tin	Kênh MQTT chạy plaintext trên cổng 1883 (mục 4.1); xảy ra khi kẻ tấn công có quyền quan sát lưu lượng mạng nội bộ	Còn tồn tại - payload JSON chưa mã hóa, cần bổ sung TLS/mTLS
Denial of Service / Trôi thời gian giữa thiết bị và gateway	Phụ thuộc đồng bộ NTP (mục 4.6.2); xảy ra khi thiết bị mất kết nối mạng tạm thời	Còn tồn tại - có thể khiến lệnh hợp lệ bị từ chối nhầm
Elevation of Privilege / Trích xuất khóa Kdev từ firmware	Khóa lưu tĩnh (hardcode) trên ESP32; xảy ra khi kẻ tấn công có quyền truy cập vật lý vào thiết bị	Còn tồn tại - chưa có cơ chế bảo vệ khóa (secure element/HSM)
Denial of Service / Quá tải bộ nhớ đệm Replay-cache	Giới hạn dung lượng cache tại gateway; xảy ra khi bị tấn công với số lượng lớn gói tin rác	Còn tồn tại - chưa được kiểm thử với tải lớn/tấn công DDoS

Bảng 5. 2 - Ánh xạ STRIDE vào hệ thống khóa cửa IoT, đối chiếu với kết quả thực nghiệm Chương 4.

5.3. Ma trận rủi ro

Áp dụng ma trận 5×5 (khả năng × ảnh hưởng), mỗi rủi ro ở Bảng 5.2 được gán mã R1–R6 và đối chiếu mức rủi ro trước/sau khi áp dụng cơ chế đề xuất (Bảng 5.3), làm cơ sở xếp hạng ưu tiên xử lý ở Bảng 5.4.

Mã	Rủi ro	Khả năng (Trước → Sau)	Ảnh hưởng	Mức rủi ro Trước	Mức rủi ro Sau
R1	Mở khóa trái phép do phát lại bản tin	Cao → Rất thấp	Cao	Cao	Thấp
R2	Giả mạo/sửa đổi lệnh điều khiển	Trung bình → Rất thấp	Cao	Trung bình–Cao	Thấp
R3	Lộ nội dung bản tin do nghe trộm	Cao → Cao (chưa xử lý)	Trung bình	Cao	Cao (không đổi)
R4	Từ chối nhằm lệnh hợp lệ do trôi thời gian	Thấp → Thấp–Trung bình	Trung bình	Thấp	Thấp–Trung bình
R5	Lộ khóa Kdev qua trích xuất firmware	Thấp (cần truy cập vật lý) → Thấp	Rất cao	Trung bình	Trung bình (không đổi)
R6	Từ chối dịch vụ do quá tải Replay-cache	Thấp → Thấp	Trung bình	Thấp	Thấp

Bảng 5. 3 - Ma trận rủi ro trước và sau khi áp dụng cơ chế chống replay.

Ưu tiên	Mã rủi ro	Lý do xếp hạng
1	R3 - Lộ nội dung bản tin	Mức rủi ro vẫn ở mức Cao, chưa được xử lý bởi cơ chế hiện tại; ảnh hưởng trực tiếp đến tính bí mật
2	R5 - Lộ khóa Kdev	Mức ảnh hưởng Rất cao nếu xảy ra (phá vỡ toàn bộ cơ chế xác thực), dù khả năng xảy ra thấp
3	R4 - Từ chối nhằm do trôi thời gian	Ảnh hưởng đến trải nghiệm và độ tin cậy vận hành, cần giám sát thêm
4	R6 - Quá tải Replay-cache	Rủi ro thấp trong điều kiện lab nhưng cần biện pháp phòng ngừa trước khi triển khai thực tế
5	R1, R2 - Replay, giả mạo lệnh	Đã giảm về mức Thấp nhờ cơ chế Timestamp+Sequence+Nonce+HMAC, không cần ưu tiên xử lý thêm

Bảng 5. 4 - Bảng ưu tiên xử lý rủi ro còn tồn tại.

Ma trận cho thấy cơ chế đề xuất giảm hiệu quả nhóm rủi ro R1, R2 liên quan trực tiếp đến replay và giả mạo lệnh - đúng với mục tiêu cốt lõi của đề tài (MT-01, MT-02) - nhưng chưa xử lý được R3 và R5, vì hai nhóm này nằm ngoài phạm vi kỹ thuật đã triển khai ở Chương 3 - 4. Đây là cơ sở để đề xuất biện pháp bổ sung ở mục 5.4.

5.4. Biện pháp giảm thiểu

Biện pháp giảm thiểu được trình bày theo từng mã rủi ro ở mục 5.3, phân biệt rõ biện pháp bảo vệ kênh truyền (channel-level) và biện pháp bảo vệ đầu-cuối (end-point-level):

Rủi ro	Biện pháp	Loại bảo vệ	Trạng thái
R1, R2	Timestamp + Sequence Number + Nonce + HMAC-SHA256 gắn vào mỗi bản tin UNLOCK/LOCK; Replay-cache lưu sequence/nonce đã dùng trong cửa sổ $\Delta t \leq 5$ giây	Đầu-cuối (endpoint)	Đã triển khai và kiểm chứng (KB-02, KB-03, KB-04)
R3	Bật TLS/mTLS cho toàn bộ kênh MQTT giữa thiết bị và gateway để loại bỏ khả năng nghe trộm nội dung bản tin dạng plaintext	Kênh truyền (channel)	Đề xuất bổ sung - chưa triển khai
R4	Đồng bộ thời gian định kỳ qua NTP và bổ sung cơ chế cảnh báo/gia hạn Δt khi phát hiện thiết bị trôi giờ vượt ngưỡng hợp lý	Đầu-cuối (endpoint)	Đề xuất bổ sung - chưa triển khai
R5	Lưu khóa chia sẻ Kdev trong secure element hoặc vùng nhớ mã hóa của vi điều khiển thay vì hardcode trực tiếp trong firmware; kết hợp cập nhật firmware ký số	Đầu-cuối (endpoint)	Đề xuất bổ sung - chưa triển khai
R6	Giới hạn tốc độ (rate-limit) theo device_id và giới hạn kích thước tối đa của Replay-cache để hạn chế nguy cơ từ chối dịch vụ	Kênh truyền + Đầu-cuối	Đề xuất bổ sung - chưa triển khai

Bảng 5. 5 - Biện pháp giảm thiểu theo từng rủi ro, phân biệt bảo vệ kênh và bảo vệ đầu-cuối.

Ghi log ACCEPT/REJECT kèm device_id, sequence, timestamp cho mọi bản tin (đã triển khai ở Chương 4) đóng vai trò biện pháp hỗ trợ chung, giúp truy vết và đối chiếu khi có tranh chấp, giảm thiểu thêm rủi ro Repudiation không nằm trong Bảng 5.2 nhưng liên quan đến toàn bộ nhóm rủi ro trên.

5.5. Rủi ro còn lại

Sau khi áp dụng cơ chế đề xuất, hệ thống còn bốn rủi ro dư (residual risk) chưa được xử lý triệt để trong phạm vi đề tài: R3 (lộ nội dung bản tin do kênh MQTT chưa mã hóa, vẫn ở mức Cao và không đổi so với trước khi áp dụng biện pháp), R5 (lộ khóa Kdev nếu kẻ tấn công có quyền truy cập vật lý vào thiết bị, ở mức Trung bình do đòi hỏi điều kiện tấn công phức tạp hơn replay thuần túy), R4 (từ chối nhằm lệnh hợp lệ khi thiết bị mất đồng bộ thời gian, ở mức Thấp–Trung bình và phụ thuộc độ ổn định kết nối mạng), và R6 (từ chối dịch vụ khi Replay-cache bị làm đầy bởi lưu lượng tấn công quy mô lớn, hiện ở mức Thấp trong điều kiện lab nhưng chưa được kiểm chứng trong điều kiện tải cao). Đây là các rủi ro được chấp nhận có kiểm soát (accepted risk) trong phạm vi Đề tài 24, với điều kiện phải xem xét lại nếu: (1) hệ thống được triển khai ngoài môi trường lab/mô phỏng lên thiết bị và mạng thật; (2) phát sinh yêu cầu lưu trữ hoặc truyền dữ liệu nhạy cảm khác ngoài lệnh điều khiển khóa/mở; hoặc (3) quy mô triển khai tăng đến mức cần chống chịu tấn công từ chối dịch vụ có chủ đích. Các rủi ro này sẽ được đối chiếu lại ở Chương 6 và đề xuất hướng xử lý tiếp trong phần hướng phát triển.

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận

Đối chiếu với bốn mục tiêu đã đề ra ở mục 1.3, đề tài đạt được kết quả như Bảng 6.1.

Mục tiêu	Mức độ đạt được	Minh chứng
MT-01 - Phân tích và mô hình hóa nguy cơ replay attack bằng attack tree và STRIDE	Đạt	Hình 2.2 (attack tree) và Bảng 2.1 (STRIDE) ở Chương 2; Bảng 5.2 mở rộng ánh xạ sang đánh giá rủi ro ở Chương 5
MT-02 - Thiết kế cơ chế chống replay (Timestamp + Sequence Number + Nonce + HMAC)	Đạt	Hình 3.1 (mô hình đề xuất) và đặc tả giao thức ở Chương 3
MT-03 - Triển khai mô phỏng và thu log/ảnh minh chứng	Đạt	Mã nguồn, cấu hình, log 4 kịch bản KB-01 đến KB-04 ở Chương 4
MT-04 - Đánh giá hiệu quả cơ chế qua số liệu và ma trận rủi ro	Đạt	Bảng số liệu đối chiếu tiêu chí 3.5 ở Chương 4; ma trận rủi ro R1 - R6 ở Chương 5

Bảng 6. 1 - Đối chiếu mục tiêu đề tài với kết quả đạt được.

Kết quả thực nghiệm cho thấy cơ chế đa lớp Timestamp + Sequence Number + Nonce + HMAC-SHA256 chặn đứng 100% các kịch bản tấn công phát lại và giả mạo lệnh trong môi trường mô phỏng, đồng thời không gây từ chối nhằm đối với lệnh hợp lệ (tỉ lệ dương tính giả

0%), với độ trễ xử lý bổ sung ở mức thấp nhờ thứ tự kiểm tra tối ưu tại gateway (mục 4.6.1). Kết quả đạt được đáp ứng đầy đủ các tiêu chí đo được đã đề ra ở mục 3.5, khẳng định cơ chế đề xuất giải quyết đúng và đủ vấn đề bảo mật đã đặt ra ở mục 1.2 cho phạm vi đề tài (giao tiếp thiết bị - gateway, môi trường mô phỏng/lab).

6.2. Hạn chế

Bên cạnh kết quả đạt được, đề tài còn các hạn chế đã phân tích chi tiết ở mục 4.6.2 và mục 5.5, được tóm tắt lại theo bốn nhóm chính:

- Cơ chế Timestamp yêu cầu thiết bị và gateway luôn đồng bộ thời gian chặt chẽ; mất kết nối tạm thời có thể khiến lệnh hợp lệ bị từ chối nhầm. Phụ thuộc đồng bộ thời gian (NTP)
- Khóa Kdev lưu tĩnh (hardcode) trên vi điều khiển, chưa có cơ chế bảo vệ khi kẻ tấn công có quyền truy cập vật lý vào thiết bị. Quản lý khóa bí mật còn thủ công
- Cơ chế hiện tại chỉ đảm bảo tính xác thực và toàn vẹn qua HMAC, chưa mã hóa payload nên vẫn có nguy cơ bị nghe trộm (Information Disclosure). Thiếu mã hóa nội dung bản tin
- Toàn bộ thử nghiệm được thực hiện trong môi trường mô phỏng (Wokwi + Mosquitto local/Docker), chưa kiểm chứng trên thiết bị phần cứng thật hoặc dưới tải mạng lớn/tấn công DDoS thực tế. Phạm vi thực nghiệm còn hẹp

6.3. Hướng phát triển

Trên cơ sở các hạn chế ở mục 6.2 và rủi ro còn lại ở mục 5.5, đề tài đề xuất năm hướng phát triển tiếp theo:

- Triển khai trên thiết bị IoT thật (ESP32 vật lý, khóa điện tử thực tế) thay vì chỉ mô phỏng trên Wokwi, nhằm kiểm chứng cơ chế trong điều kiện mạng và phần cứng thực.
- Bổ sung TLS/mTLS cho toàn bộ kênh giao tiếp MQTT để giải quyết dứt điểm rủi ro R3 (lộ nội dung bản tin), kết hợp bảo vệ kênh truyền với cơ chế chống replay ở tầng ứng dụng đã có.
- Xây dựng dashboard giám sát thời gian thực hiển thị trạng thái ACCEPT/REJECT, cảnh báo bất thường và lịch sử tấn công, giúp quản trị viên theo dõi hệ thống trực quan hơn thay vì chỉ đọc log dạng văn bản.
- Mở rộng bộ dữ liệu và kịch bản thử nghiệm (tăng số lượng thiết bị mô phỏng, thử nghiệm dưới tải cao/tấn công DDoS có chủ đích) để đánh giá rủi ro R6 một cách định lượng và đầy đủ hơn.
- Nghiên cứu giải pháp quản lý khóa an toàn hơn (secure element, TPM, hoặc cơ chế trao đổi khóa động) để xử lý rủi ro R5 thay vì lưu khóa tĩnh trong firmware.

DANH MỤC NGUỒN TÀI LIỆU THAM KHẢO

1. OWASP Internet of Things Project. <https://owasp.org/www-project-internet-of-things/>. 06/07/2026. Mối đe dọa/lỗ hổng IoT - mục 2.3, 5.2.
2. NIST SP 800-63B - Digital Identity Guidelines: Authentication and Lifecycle Management. <https://pages.nist.gov/800-63-3/sp800-63b.html>. 06/07/2026. Khái niệm xác thực, tính tươi (freshness) - mục 2.2.
3. RFC 2104 - HMAC: Keyed-Hashing for Message Authentication (H. Krawczyk, M. Bellare, R. Canetti, IETF, 1997). <https://www.rfc-editor.org/rfc/rfc2104>. 15/07/2026. Thiết kế cơ chế chống giả mạo bằng HMAC - Chương 3.
4. Eclipse Mosquitto - MQTT Broker Documentation. <https://mosquitto.org/documentation/>. 25/07/2026. Cấu hình gateway/broker - Chương 3, 4.
5. Wokwi Docs - ESP32 Simulation Guide. <https://docs.wokwi.com/>. 30/07/2026. Mô phỏng thiết bị IoT - Chương 4.
6. Kho lưu trữ mã nguồn Đề tài 24. <https://github.com/NgAnh205/NgAnh-Chong-Replay-Attack-IoT>. 31/07/2026. Lưu trữ code, config, log toàn bộ đề tài - Chương 4.